

CSPTF

Crypto Security Penetration Testing Framework

CSPTF Specification

Crypto Security Penetration Testing Framework

Especificación normativa v0.1 - español

Autor: Edwin Javier Peñuela Camacho

Versión: 0.1.0-draft

Fecha: 2026-07-31

Licencia: Apache-2.0

BORRADOR FUNDACIONAL - NO ES CERTIFICACIÓN

Control del documento

Documento	CSPTF Specification
Framework version	0.1.0-draft
Estado	Borrador público fundacional
Autor inicial	Edwin Javier Peñuela Camacho
Fecha	2026-07-31
Licencia	Apache-2.0
Repositorio	https://github.com/sr-maximus/CSPTF
Limitación	No constituye certificación, garantía de seguridad, asesoría legal ni autorización para ejecutar pruebas.

Cómo utilizar esta especificación

Esta especificación define el núcleo metodológico y el catálogo consolidado CSPTF. Debe utilizarse junto con la autorización legal, las Rules of Engagement, los catálogos machine-readable y las fuentes especializadas mapeadas.

Los términos DEBE y NO DEBE son normativos. DEBERÍA permite una excepción documentada y aceptada. PUEDE indica una opción. Un test case describe una forma de evaluación, pero nunca concede permiso para ejecutarla.

La versión v0.1.0-draft no constituye certificación. Los pesos del scoring, los mappings y la completitud de dominios requieren validación comunitaria e independiente.

Contenido

- Carta del framework
- Alcance y taxonomía
- Reglas de compromiso
- Ciclo de evaluación
- Perfiles de aseguramiento
- Evidencia y confianza
- Modelo de riesgo
- Identificadores
- Modelo de findings
- Conformidad
- Estándar de reporte
- Glosario
- 20 dominios
- Crosswalk

- Investigación y validación
- Referencias

00 - Carta del framework

Misión

CSPTF proporciona un método repetible, autorizado y basado en evidencia para evaluar la seguridad del sistema completo de activos digitales, no solamente el código de contratos inteligentes.

Objetivos

- integrar testing técnico, económico, operacional y de gobernanza;
- establecer identificadores estables y catálogos machine-readable;
- exigir autorización explícita y ejecución segura;
- hacer visibles la calidad de evidencia y la incertidumbre;
- permitir tailoring para arquitecturas y cadenas diferentes;
- mapear sin duplicar estándares especializados;
- mejorar comparabilidad sin eliminar contexto;
- cerrar el ciclo mediante remediación y retest.

Fuera de objetivo

CSPTF no es:

- autorización legal;
- garantía de seguridad, solvencia o cumplimiento;
- manual para explotar sistemas en producción;
- sustituto de prueba criptográfica, verificación formal o auditoría financiera;
- programa de certificación en v0.1;
- framework limitado a EVM o blockchains públicas.

Unidad de evaluación

La unidad es el **sistema de activos digitales**, representado como un grafo de activos, actores, fronteras de confianza, componentes, estados, flujos de valor, dependencias externas y mecanismos de recuperación.

Propiedades de calidad

Una evaluación conforme debe ser autorizada, delimitada, threat-informed, reproducible, respaldada por evidencia, contextualizada por riesgo, segura, explícita sobre limitaciones, revisable de manera independiente y cerrada mediante remediación y retest.

01 - Alcance y taxonomía

Capas del sistema

CSPTF modela diez capas interdependientes:

1. negocio, gobernanza y regulación;
2. diseño económico y comportamiento de mercado;
3. identidad, custodia y firma;
4. aplicación y lógica de contratos;
5. protocolo, consenso y comunicación cross-chain;
6. APIs, clientes e interfaces;
7. infraestructura, cloud y supply chain;
8. telemetría, fraude y threat intelligence;
9. respuesta, recuperación y reservas;
10. terceros y dependencias del ecosistema.

Registro de alcance

El scope DEBE identificar:

- propietario legal y autoridad que autoriza;
- objetivo de la evaluación;
- activos incluidos y exclusiones explícitas;
- cadenas, redes, ambientes y direcciones de contratos;
- versiones de source, bytecode, build y deployment;
- wallets, firmantes, custodia y límites;
- APIs, nodos, cloud accounts, dominios y repositories;
- terceros y límites de dependencia;
- clasificación de datos;
- ventanas y técnicas prohibidas;
- presupuestos de transacciones, gas y pérdida;
- rollback y reconciliación;
- reporte y divulgación.

Arquetipos

Puede adaptarse a L1/L2, dApp, protocolo DeFi, bridge, CEX/broker, custodio, wallet provider, token/NFT platform, blockchain empresarial, operador de validadores/nodos o developer platform.

Regla de tailoring

Un dominio solo puede marcarse no aplicable cuando se documentan ausencia de activos/supuestos, evidencia, transferencia del riesgo a terceros y aprobación de la exclusión.

02 - Reglas de compromiso (Rules of Engagement)

Autorización obligatoria

Ningún test comienza sin autorización firmada que identifique owner, tester, sistemas, ambientes, fechas, contactos, técnicas y límites. La autorización DEBE permitir a un tercero decidir si una acción estaba permitida.

Prioridad de ambientes

Debe utilizarse el ambiente más seguro que responda la pregunta:

11. revisión estática y documental;
12. unit/integration local;
13. simulación aislada;
14. fork determinístico o shadow environment;
15. testnet;
16. staging/preproducción;
17. observación read-only de producción;
18. prueba activa de producción expresamente autorizada.

Descender exige razón documentada y controles adicionales.

Salvaguardas de producción

Las pruebas activas requieren:

- tests IDs individualizados;
- approver y stop authority;
- monitoring y canal de comunicación;
- backup, rollback o recuperación compensatoria;
- cero activos de clientes por defecto;
- límites de transacciones, gas, volumen y tiempo;
- rate/concurrency limits;
- reconciliación antes/después;
- criterios de terminación;
- conversión a incidente;
- custodia de evidencia y divulgación.

Acciones prohibidas por defecto

Sin autorización individual, NO DEBE:

- mover, bloquear, quemar o exponer activos reales de clientes;
- degradar consenso, disponibilidad o integridad de mercado;
- manipular precios o crear actividad engañosa;
- usar credenciales, seeds o keys robadas;
- crear persistencia no controlada;

- evadir controles legales de identidad, sanciones o crimen financiero;
- acceder a datos ajenos al objetivo;
- divulgar una falla no corregida que aumente materialmente el riesgo.

Stop conditions

Detener ante movimiento inesperado, posible afectación de integridad/disponibilidad/solvencia, scope incierto, pérdida de monitoring, exposición de terceros, actividad adversaria real, imposibilidad de rollback/reconciliación o instrucción del stop authority.

Evidencia y limpieza

Cada acción activa debe registrar operador, tiempo, target, propósito, efecto esperado, efecto observado y cleanup. Identidades, allowances, roles, contratos, datos e infraestructura de prueba deben revocarse o eliminarse.

03 - Ciclo de evaluación

Fase 0 - Autorización y gobernanza

Confirmar autoridad, independencia, alcance, RoE, presupuestos, seguridad, comunicación y restricciones legales.

Gate: autorización y test plan aprobados.

Fase 1 - Contexto y descomposición

Modelar arquitectura, fronteras, activos, identidades, datos y flujos de valor. Definir invariantes de seguridad y solvencia.

Gate: system model aceptado por owners técnicos y de negocio.

Fase 2 - Threat intelligence y attack surface

Usar AADAPT, ATT&CK, incidentes públicos, abuse cases y dependency intelligence.

Gate: threat model priorizado.

Fase 3 - Tailoring y diseño

Seleccionar dominios, controles, tests y perfil. Definir ambientes, tools, datasets, criterios y limitaciones.

Gate: test matrix aprobada.

Fase 4 - Evaluación no invasiva

Revisar diseño, código, configuración, permisos, logs, builds, reservas y runbooks.

Gate: evidencia completa.

Fase 5 - Validación adversarial controlada

Usar identidades de prueba, datos sintéticos, requests no destructivos y actividad acotada.

Gate: sin condición de seguridad pendiente.

Fase 6 - Simulación económica y de protocolo

Modelar incentivos, liquidez, oráculos, ordering, liquidaciones, consenso, cross-chain y fallas en ambiente determinístico.

Gate: invariantes y limitaciones documentados.

Fase 7 - Validación segura de exploitability

Demostrar solo cuando sea necesario y preferiblemente en fork, testnet o laboratorio. Producción exige autorización excepcional.

Gate: prueba reproducible, cleanup y ausencia de efectos no controlados.

Fase 8 - Detección y respuesta

Validar telemetría, alertas, triage, contención, reconciliación, comunicación y recovery.

Gate: gaps asignados.

Fase 9 - Riesgo y reporte

Crear findings con evidencia, root cause, path, impacto, confidence, assets, riesgo y remediación.

Gate: quality review y factual validation.

Fase 10 - Remediación y retest

Repetir la condición y rutas adyacentes; verificar invariantes.

Gate: closure evidence o residual risk aceptado.

Fase 11 - Aseguramiento continuo

Rastrear cambios de código, dependencias, contratos, signers, parámetros, infraestructura, liquidez y amenazas.

04 - Perfiles de aseguramiento

Los perfiles determinan profundidad mínima, evidencia e independencia; no certifican seguridad.

Perfil	Uso típico	Evidencia mínima	Profundidad	Independencia
AP1 Baseline	prototipos, pilotos de bajo valor	E2 configuración	review + validación funcional acotada	revisión interna calificada
AP2 Enhanced	producción con activos materiales	E3 observada	dynamic testing threat-informed	reviewer independiente del implementador
AP3 Critical	custodia, CEX, bridges, validadores, DeFi	E4 adversarial	simulation, property testing y failure exercises	equipo especialista independiente
AP4 Systemic	impacto material de	E5 independiente	multi-team review, crisis y modelado	assurance organizacionalmente

Perfil	Uso típico	Evidencia mínima	Profundidad	Independencia
	mercado/institucional/cross-chain		sistémico	independiente

Selección

Valorar 0-5: activos, volumen, usuarios, irreversibilidad, composabilidad, custodia, consenso/mercado, regulación, novedad y dificultad de recovery. AP1 no es apropiado cuando un factor es 4-5 sin rationale compensatorio.

Herencia y perfiles mixtos

Los perfiles superiores heredan requisitos inferiores. Un sistema puede asignar AP3 a custody/bridge y AP2 a API; debe mostrarlo por dominio y justificarlo.

06 - Evidencia y confianza

Niveles

Nivel	Nombre	Significado
E0	Declarativa	afirmación o questionnaire sin verificar
E1	Documental	policy, diagram, ticket o design record
E2	Configuración	source, build, configuration o control artifact
E3	Observada	logs, queries o runtime output directos
E4	Adversarial	test controlado reproduce propiedad o falla
E5	Independiente	repetición independiente o attestation

Registro

Cada evidencia DEBE incluir ID, source/owner, fecha/hora/timezone, ambiente/versión, collector, hash cuando aplique, sensibilidad, relación con control/test/finding, limitaciones y retención.

Confianza

- **C1 Low:** supuestos materiales no verificados.
- **C2 Moderate:** múltiples indicadores con gaps.
- **C3 High:** evidencia directa y repetible.
- **C4 Very high:** reproducción independiente y traceability completa.

Tool output por sí solo es E2 como máximo salvo validación de reachability, preconditions e impact. La contradicción entre evidencias debe resolverse o reducir confidence.

05 - Modelo preliminar de riesgo

Modelo v0.1 sujeto a calibración empírica y a validación de concordancia entre evaluadores.

Impacto (0-5)

- **F:** financiero.
- **I:** integridad.
- **A:** disponibilidad.
- **P:** privacidad.
- **G:** gobernanza.
- **S:** sistémico.
- **R:** irreversibilidad.

$$\text{Impact} = 0.25F + 0.15I + 0.10A + 0.10P + 0.10G + 0.15S + 0.15R$$

Probabilidad (0-5)

- **E:** explotabilidad.
- **X:** exposición.
- **Q:** precondiciones; la puntuación aumenta cuando existen menos precondiciones.
- **M:** incentivo.
- **C:** composabilidad.

$$\text{Likelihood} = 0.30E + 0.20X + 0.15Q + 0.20M + 0.15C$$

$$\text{RawRisk} = 100 \times (\text{Impact} / 5) \times (\text{Likelihood} / 5)$$

$$\text{Risk} = \text{floor}(\text{RawRisk} + 0.5)$$

Ejemplo: Impact=3.90 y Likelihood=3.75 producen Risk=59, banda Alta.

Bandas preliminares

Score	Banda
0-9	Informativo
10-29	Bajo
30-49	Medio
50-69	Alto
70-89	Crítico
90-100	Sistémico

Overrides y agregación

Una ruta creíble hacia un firmante raíz, una capacidad de emisión irrestricta, una mayoría de validadores de bridge, el libro de reservas o un retiro irreversible de alto valor no puede clasificarse por debajo de Alto sin una justificación explícita. No deben promediarse hallazgos sin conservar el riesgo máximo, la concentración, las causas compartidas, las dependencias correlacionadas y la incertidumbre.

Riesgo, evidencia y confianza

Se reportan por separado. Un escenario de alto impacto puede tener baja confianza.

07 - Identificadores

Objeto	Patrón	Ejemplo
Dominio	`CSPTF-DOM-NN`	`CSPTF-DOM-10`
Control	`CSPTF-CTRL-CODE-NNN`	`CSPTF-CTRL-BRG-004`
Test	`CSPTF-TEST-CODE-NNN`	`CSPTF-TEST-BRG-009`
Amenaza	`CSPTF-THRT-CODE-NNN`	`CSPTF-THRT-KEY-001`
Debilidad	`CSPTF-WEAK-CODE-NNN`	`CSPTF-WEAK-SCT-002`
Finding	`CSPTF-FIND-NNNN`	`CSPTF-FIND-0042`
Evidencia	`CSPTF-EVID-NNNN`	`CSPTF-EVID-0088`

Los IDs no codifican severidad, no se reutilizan y permanecen estables tras release. Los mappings declaran estado proposed, reviewed, verified o deprecated.

08 - Modelo de findings

Un finding es una afirmación verificable respaldada por evidencia.

Campos obligatorios

- ID, title y status;
- assets, versions, networks y addresses;
- tests, controls, threats y weaknesses;
- observation y expected property;
- reproducción segura;
- preconditions y exploit path;
- dimensiones de impacto y probabilidad;
- risk band y override;
- evidence level y confidence;

- root cause;
- remediation y compensating controls;
- owner/target;
- disclosure restrictions;
- retest y residual risk.

Estados

draft -> validated -> accepted -> remediation in progress -> ready for retest -> closed

Estados alternos: risk accepted, duplicate, not applicable, false positive o superseded. Cada cambio registra actor, tiempo, rationale y evidencia.

Causa raíz

No crear un finding por cada línea de scanner cuando comparten causa; tampoco mezclar riesgos no relacionados.

09 - Conformidad de evaluaciones

CSPTF v0.1 permite declarar **assessment conformant - draft**, no product certification.

La evaluación debe:

19. identificar versión;
20. tener autorización y RoE;
21. definir arquetipo y scope;
22. asignar perfil por dominio;
23. registrar applicable, excluded y not-tested;
24. usar IDs CSPTF;
25. preservar evidencia y confidence;
26. aplicar scoring o alternativa transparente;
27. reportar limitaciones y residual risk;
28. incluir remediation y retest;
29. pasar validación estructural.

No puede declarar certificación, garantía, endorsement ni compliance automático con fuentes mapeadas.

Cobertura

Reportar por separado control, tests, evidence, threats, domains y retest. Un porcentaje único puede ocultar rutas críticas.

10 - Estándar de reporte

Reporte ejecutivo

- decisión soportada;
- scope y assurance;
- sistema y flujos de valor;

- riesgo máximo y concentración;
- escenarios críticos y efecto de negocio;
- fortalezas y limitaciones;
- acciones, owners y horizontes;
- residual risk y retest.

Reporte técnico

- autorización y RoE;
- arquitectura y threat model;
- inventory versionado;
- test matrix;
- métodos, tools y limitaciones;
- evidence register;
- findings;
- calculations;
- detección/respuesta;
- remediation;
- exclusions;
- hashes y anexos.

Reglas de lenguaje

Distinguir hecho observado, comportamiento reproducido, inferencia, supuesto e hipótesis no probada. Evitar “seguro”, “inhackeable” o “fully compliant” sin sustento.

Distribución

Aplicar acceso por roles, cifrado, clasificación, retención controlada y resumen sanitizado para divulgación coordinada.

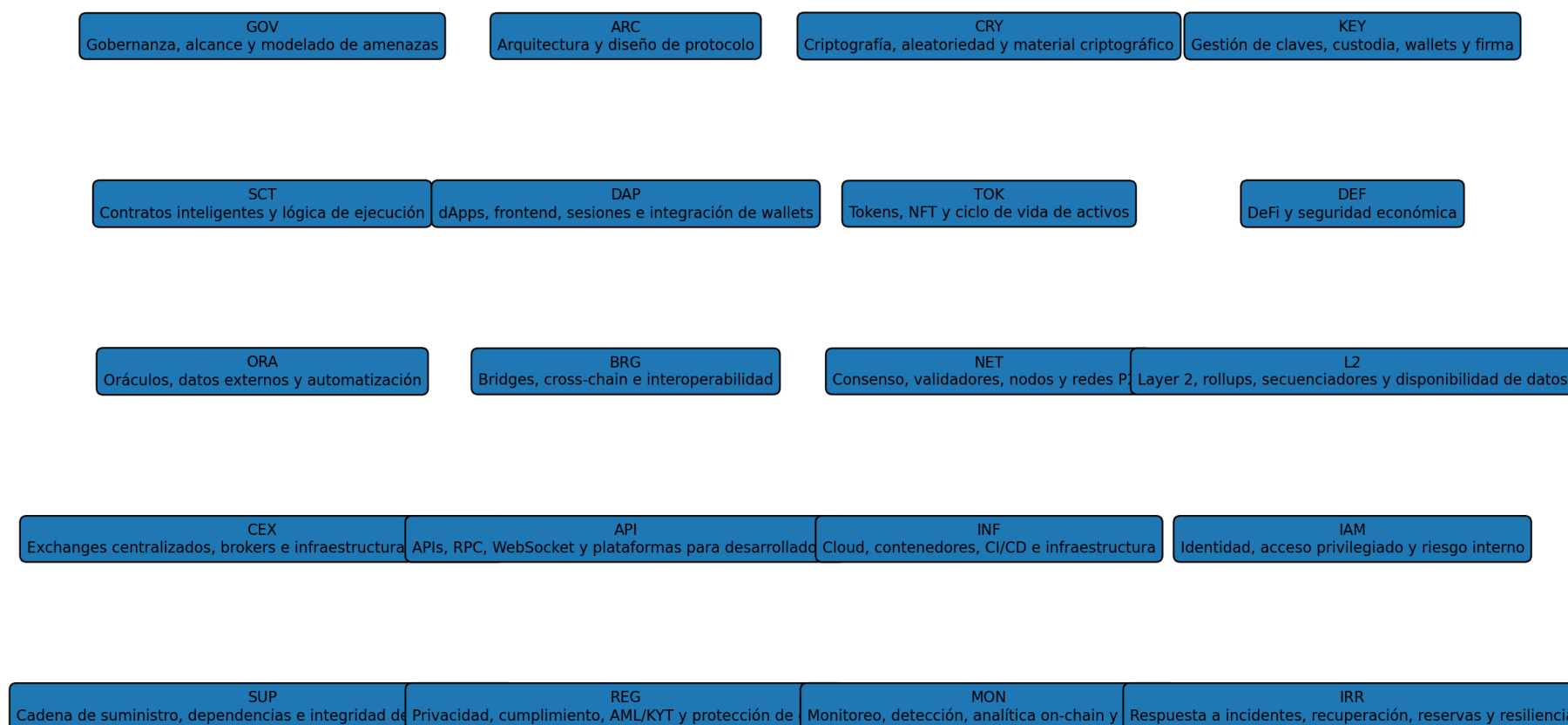
11 - Glosario

- **Activo:** elemento de valor o necesario para proteger valor.
- **Perfil de aseguramiento:** profundidad e independencia mínimas.
- **Bridge:** mecanismo que comunica o representa activos/estado entre cadenas.
- **CeFi:** servicio financiero de activos digitales operado centralmente.
- **Composabilidad:** interacción entre componentes, a menudo atómica.
- **Custodia:** control y protección de autoridad de firma o activos.
- **DeFi:** protocolo financiero implementado en sistemas descentralizados.
- **Evidencia:** artefacto que soporta o refuta una conclusión.
- **Finding:** afirmación de riesgo respaldada por evidencia.
- **Fork:** copia aislada del estado de una cadena.
- **Invariante:** propiedad que permanece verdadera en estados válidos.
- **MPC:** multi-party computation para distribuir operaciones de clave.
- **Oráculo:** mecanismo que entrega datos externos a blockchain.
- **Relayer:** actor off-chain que envía mensajes o transacciones.

- **Rollup:** Layer 2 que publica datos o pruebas en una base layer.
- **Impacto sistémico:** propagación más allá del componente afectado.
- **Test case:** procedimiento autorizado para evaluar una propiedad.
- **Amenaza:** actor/acción/escenario capaz de causar daño.
- **Debilidad:** condición que habilita o amplifica una amenaza.

Dominios CSPTF

CSPTF: arquitectura de 20 dominios



Gobernanza + técnica + economía + operaciones + resiliencia

Figura 1. Arquitectura CSPTF de veinte dominios.

Cada dominio se selecciona a partir de arquitectura, flujos de valor y perfil de aseguramiento. La exclusión exige evidencia y aprobación. Los perfiles superiores heredan los requisitos de perfiles inferiores.

Domain ID	Código	Nombre en español	English name
CSPTF-DOM-01	GOV	Gobernanza, alcance y modelado de amenazas	Governance, Scope and Threat Modeling
CSPTF-DOM-02	ARC	Arquitectura y diseño de protocolo	Architecture and Protocol Design
CSPTF-DOM-03	CRY	Criptografía, aleatoriedad y material criptográfico	Cryptography, Randomness and Cryptographic Material
CSPTF-DOM-04	KEY	Gestión de claves, custodia, wallets y firma	Key Management, Custody, Wallets and Signing
CSPTF-DOM-05	SCT	Contratos inteligentes y lógica de ejecución	Smart Contracts and Runtime Logic
CSPTF-DOM-06	DAP	dApps, frontend, sesiones e integración de wallets	dApps, Frontend, Sessions and Wallet Integration
CSPTF-DOM-07	TOK	Tokens, NFT y ciclo de vida de activos	Tokens, NFTs and Asset Lifecycle
CSPTF-DOM-08	DEF	DeFi y seguridad económica	DeFi and Economic Security
CSPTF-DOM-09	ORA	Oráculos, datos externos y automatización	Oracles, External Data and Automation
CSPTF-DOM-10	BRG	Bridges, cross-chain e interoperabilidad	Bridges, Cross-chain and Interoperability
CSPTF-DOM-11	NET	Consenso, validadores, nodos y redes P2P	Consensus, Validators, Nodes and P2P Networks
CSPTF-DOM-12	L2	Layer 2, rollups, secuenciadores y disponibilidad de datos	Layer 2, Rollups, Sequencers and Data Availability
CSPTF-DOM-13	CEX	Exchanges centralizados, brokers e infraestructura de mercado	Centralized Exchanges, Brokers and Market Infrastructure
CSPTF-DOM-14	API	APIs, RPC, WebSocket y plataformas para desarrolladores	APIs, RPC, WebSocket and Developer Platforms
CSPTF-DOM-15	INF	Cloud, contenedores, CI/CD e infraestructura	Cloud, Containers, CI/CD and Infrastructure
CSPTF-DOM-16	IAM	Identidad, acceso privilegiado y riesgo interno	Identity, Privileged Access and Insider Risk
CSPTF-DOM-17	SUP	Cadena de suministro, dependencias e integridad de construcción	Supply Chain, Dependencies and Build Integrity
CSPTF-DOM-18	REG	Privacidad, cumplimiento, AML/KYT y protección de datos	Privacy, Compliance, AML/KYT and Data Protection
CSPTF-DOM-19	MON	Monitoreo, detección, analítica on-chain y fraude	Monitoring, Detection, On-chain Analytics and Fraud
CSPTF-DOM-20	IRR	Respuesta a incidentes, recuperación, reservas y resiliencia	Incident Response, Recovery, Reserves and Resilience

CSPTF-DOM-01 - GOV: Gobernanza, alcance y modelado de amenazas

English: Governance, Scope and Threat Modeling

Establecer autorización, objetivos, límites, responsables, supuestos, apetito de riesgo y modelos de amenaza antes de ejecutar cualquier prueba.

Activos principales: mandato de evaluación; inventario de activos; matriz RACI; modelo de amenazas; presupuestos de pérdida; criterios de detención.

Alineación de tácticas AADAPT: Reconnaissance, Resource Development, Initial Access, Impact, Fraud.

NIST CSF 2.0: GV, ID.

OWASP y fuentes relacionadas: SCSTG engagement planning; SCSVS governance context.

Controles

ID	AP	Control	Requisito normativo	Evidencia esperada
CSPTF-CTRL-GOV-001	AP1	Gobierno y responsabilidad del programa	La organización DEBE definir, aprobar, implementar, monitorear y revisar gobierno y responsabilidad del programa, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con gobierno y responsabilidad del programa.
CSPTF-CTRL-GOV-002	AP1	Inventario y clasificación de activos digitales	La organización DEBE definir, aprobar, implementar, monitorear y revisar inventario y clasificación de activos digitales, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con inventario y clasificación de activos digitales.
CSPTF-CTRL-GOV-003	AP2	Reglas de compromiso y autorización	La organización DEBE definir, aprobar, implementar, monitorear y revisar reglas de compromiso y autorización, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con reglas de compromiso y autorización.
CSPTF-CTRL-GOV-004	AP2	Modelado de amenazas orientado al negocio	La organización DEBE definir, aprobar, implementar, monitorear y revisar modelado de amenazas orientado al negocio, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con modelado de amenazas orientado al negocio.
CSPTF-CTRL-GOV-005	AP2	Gestión de terceros y dependencias críticas	La organización DEBE definir, aprobar, implementar, monitorear y revisar gestión de terceros y dependencias críticas, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con gestión de terceros y dependencias críticas.
CSPTF-CTRL-GOV-006	AP3	Presupuestos de riesgo, pérdida y transacción	La organización DEBE definir, aprobar, implementar, monitorear y revisar presupuestos de riesgo, pérdida y transacción, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con presupuestos de riesgo, pérdida y transacción.
CSPTF-CTRL-GOV-007	AP3	Gestión de cambios durante la evaluación	La organización DEBE definir, aprobar, implementar, monitorear y revisar gestión de cambios durante la evaluación, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con gestión de cambios durante la evaluación.

ID	AP	Control	Requisito normativo	Evidencia esperada
			aceptadas.	
CSPTF-CTRL-GOV-008	AP4	Aceptación, excepción y cierre de hallazgos	La organización DEBE definir, aprobar, implementar, monitorear y revisar aceptación, excepción y cierre de hallazgos, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con aceptación, excepción y cierre de hallazgos.

Casos de prueba autorizados

Regla de seguridad: priorizar review, laboratorio local, fork, testnet y staging. Las acciones activas de producción requieren autorización individual, monitoring, límites, stop authority y reconciliación.

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
CSPTF-TEST-GOV-001	AP1	Verificar la autorización y el alcance formal	Determinar, mediante evidencia verificable y validación no destructiva, si verificar la autorización y el alcance formal reduce el riesgo esperado. Revisar diseño y configuración relacionados con verificar la autorización y el alcance formal, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden verificar la autorización y el alcance formal. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-GOV-002	AP1	Validar el inventario de activos y flujos de valor	Determinar, mediante evidencia verificable y validación no destructiva, si validar el inventario de activos y flujos de valor reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar el inventario de activos y flujos de valor, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar el inventario de activos y flujos de valor. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-GOV-003	AP1	Revisar roles, escalamiento y autoridad de detención	Determinar, mediante evidencia verificable y validación no destructiva, si revisar roles, escalamiento y autoridad de detención reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar roles, escalamiento y autoridad de detención, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar roles, escalamiento y autoridad de detención. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-GOV-004	AP2	Evaluar el modelo de amenazas y supuestos	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar el modelo de amenazas y supuestos reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar el modelo de amenazas y supuestos, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar el modelo de amenazas y supuestos. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-GOV-005	AP2	Comprobar exclusiones y dependencias de terceros	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar exclusiones y dependencias de terceros reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar exclusiones y dependencias de terceros, contrastarlos con	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar exclusiones y dependencias de terceros. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
			invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-GOV-006	AP2	Validar presupuestos de pérdida, gas y transacciones	Determinar, mediante evidencia verificable y validación no destructiva, si validar presupuestos de pérdida, gas y transacciones reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar presupuestos de pérdida, gas y transacciones, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar presupuestos de pérdida, gas y transacciones. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-GOV-007	AP2	Revisar ventanas, monitoreo y comunicaciones	Determinar, mediante evidencia verificable y validación no destructiva, si revisar ventanas, monitoreo y comunicaciones reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar ventanas, monitoreo y comunicaciones, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar ventanas, monitoreo y comunicaciones. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-GOV-008	AP3	Comprobar criterios de evidencia y custodia	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar criterios de evidencia y custodia reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar criterios de evidencia y custodia, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar criterios de evidencia y custodia. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-GOV-009	AP3	Evaluar la gestión de cambios de alcance	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar la gestión de cambios de alcance reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar la gestión de cambios de alcance, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar la gestión de cambios de alcance. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-GOV-010	AP3	Validar el tratamiento de datos sensibles	Determinar, mediante evidencia verificable y validación no destructiva, si validar el tratamiento de datos sensibles reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar el tratamiento de datos sensibles, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar el tratamiento de datos sensibles. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-GOV-011	AP4	Revisar aceptación de riesgo y excepciones	Determinar, mediante evidencia verificable y validación no destructiva, si revisar aceptación de riesgo y excepciones reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar aceptación de riesgo y excepciones, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar aceptación de riesgo y excepciones. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-GOV-012	AP4	Ejecutar una mesa de crisis previa a pruebas críticas	Determinar, mediante evidencia verificable y validación no destructiva, si ejecutar una mesa de crisis previa a pruebas críticas reduce el riesgo	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
			esperado. Revisar diseño y configuración relacionados con ejecutar una mesa de crisis previa a pruebas críticas, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	invaliden ejecutar una mesa de crisis previa a pruebas críticas. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.

Amenazas y debilidades

Threat ID	Escenario de amenaza	Weakness ID	Patrón de debilidad
CSPTF-THRT-GOV-001	Pruebas sin autorización efectiva	CSPTF-WEAK-GOV-001	Alcance ambiguo
CSPTF-THRT-GOV-002	Activos críticos omitidos del alcance	CSPTF-WEAK-GOV-002	Inventario incompleto
CSPTF-THRT-GOV-003	Conflictos de interés o independencia insuficiente	CSPTF-WEAK-GOV-003	Reglas de detención inexistentes
CSPTF-THRT-GOV-004	Cambios no controlados durante el ejercicio	CSPTF-WEAK-GOV-004	RACI no definido
CSPTF-THRT-GOV-005	Aceptación de riesgo sin autoridad competente	CSPTF-WEAK-GOV-005	Evidencia sin cadena de custodia

Gate de cierre del dominio

- Aplicabilidad y exclusiones justificadas.
- Controles seleccionados con evidencia proporcional al perfil.
- Tests clasificados pass, fail, inconclusive o formally not-tested.
- Findings con owner, plazo, disclosure handling y retest.
- Dependencias críticas y riesgo residual visibles para el decision maker.

CSPTF-DOM-02 - ARC: Arquitectura y diseño de protocolo

English: Architecture and Protocol Design

Evaluar fronteras de confianza, invariantes, flujos de valor, estados, dependencias y propiedades de seguridad del sistema completo.

Activos principales: diagramas de arquitectura; invariantes; máquinas de estado; flujos de fondos; fronteras de confianza; supuestos de protocolo.

Alineación de tácticas AADAPT: Execution, Privilege Escalation, Defense Evasion, Impact, Fraud.

NIST CSF 2.0: GV, ID, PR.

OWASP y fuentes relacionadas: SCSTG architecture and threat modeling; SCSVS architecture.

Controles

ID	AP	Control	Requisito normativo	Evidencia esperada
CSPTF-CTRL-ARC-001	AP1	Arquitectura documentada y versionada	La organización DEBE definir, aprobar, implementar, monitorear y revisar arquitectura documentada y versionada, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con arquitectura documentada y versionada.
CSPTF-CTRL-ARC-002	AP1	Fronteras de confianza explícitas	La organización DEBE definir, aprobar, implementar, monitorear y revisar fronteras de confianza explícitas, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con fronteras de confianza explícitas.
CSPTF-CTRL-ARC-003	AP2	Invariantes de seguridad y solvencia	La organización DEBE definir, aprobar, implementar, monitorear y revisar invariantes de seguridad y solvencia, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con invariantes de seguridad y solvencia.
CSPTF-CTRL-ARC-004	AP2	Máquinas de estado completas	La organización DEBE definir, aprobar, implementar, monitorear y revisar máquinas de estado completas, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con máquinas de estado completas.
CSPTF-CTRL-ARC-005	AP2	Separación de funciones y planos	La organización DEBE definir, aprobar, implementar, monitorear y revisar separación de funciones y planos, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con separación de funciones y planos.
CSPTF-CTRL-ARC-006	AP3	Patrones seguros de actualización y migración	La organización DEBE definir, aprobar, implementar, monitorear y revisar patrones seguros de actualización y migración, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con patrones seguros de actualización y migración.
CSPTF-CTRL-ARC-007	AP3	Degradación segura y circuit breakers	La organización DEBE definir, aprobar, implementar, monitorear y revisar degradación segura y circuit breakers, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con degradación segura y circuit breakers.
CSPTF-CTRL-ARC-008	AP4	Análisis de composabilidad y dependencias	La organización DEBE definir, aprobar,	Política o diseño aprobado; configuración o

ID	AP	Control	Requisito normativo	Evidencia esperada
			implementar, monitorear y revisar análisis de composabilidad y dependencias, manteniendo evidencia trazable y excepciones formalmente aceptadas.	artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con análisis de composabilidad y dependencias.

Casos de prueba autorizados

Regla de seguridad: priorizar review, laboratorio local, fork, testnet y staging. Las acciones activas de producción requieren autorización individual, monitoring, límites, stop authority y reconciliación.

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
CSPTF-TEST-ARC-001	AP1	Reconstruir la arquitectura lógica y física	Determinar, mediante evidencia verificable y validación no destructiva, si reconstruir la arquitectura lógica y física reduce el riesgo esperado. Revisar diseño y configuración relacionados con reconstruir la arquitectura lógica y física, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden reconstruir la arquitectura lógica y física. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-ARC-002	AP1	Trazar flujos de activos y mensajes	Determinar, mediante evidencia verificable y validación no destructiva, si trazar flujos de activos y mensajes reduce el riesgo esperado. Revisar diseño y configuración relacionados con trazar flujos de activos y mensajes, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden trazar flujos de activos y mensajes. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-ARC-003	AP1	Validar fronteras de confianza	Determinar, mediante evidencia verificable y validación no destructiva, si validar fronteras de confianza reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar fronteras de confianza, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar fronteras de confianza. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-ARC-004	AP2	Comprobar invariantes de seguridad	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar invariantes de seguridad reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar invariantes de seguridad, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar invariantes de seguridad. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-ARC-005	AP2	Revisar máquinas de estado y transiciones	Determinar, mediante evidencia verificable y validación no destructiva, si revisar máquinas de estado y transiciones reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar máquinas de estado y transiciones, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar máquinas de estado y transiciones. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
CSPTF-TEST-ARC-006	AP2	Evaluar separación de funciones	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar separación de funciones reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar separación de funciones, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar separación de funciones. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-ARC-007	AP2	Examinar actualización y migración	Determinar, mediante evidencia verificable y validación no destructiva, si examinar actualización y migración reduce el riesgo esperado. Revisar diseño y configuración relacionados con examinar actualización y migración, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden examinar actualización y migración. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-ARC-008	AP3	Validar modos degradados y pausas	Determinar, mediante evidencia verificable y validación no destructiva, si validar modos degradados y pausas reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar modos degradados y pausas, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar modos degradados y pausas. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-ARC-009	AP3	Analizar dependencias externas críticas	Determinar, mediante evidencia verificable y validación no destructiva, si analizar dependencias externas críticas reduce el riesgo esperado. Revisar diseño y configuración relacionados con analizar dependencias externas críticas, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden analizar dependencias externas críticas. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-ARC-010	AP3	Revisar composabilidad y efectos emergentes	Determinar, mediante evidencia verificable y validación no destructiva, si revisar composabilidad y efectos emergentes reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar composabilidad y efectos emergentes, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar composabilidad y efectos emergentes. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-ARC-011	AP4	Comprobar supuestos de tiempo y finalidad	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar supuestos de tiempo y finalidad reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar supuestos de tiempo y finalidad, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar supuestos de tiempo y finalidad. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-ARC-012	AP4	Ejecutar revisión adversarial de arquitectura	Determinar, mediante evidencia verificable y validación no destructiva, si ejecutar revisión adversarial de arquitectura reduce el riesgo esperado. Revisar diseño y configuración relacionados con ejecutar revisión adversarial de arquitectura, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden ejecutar revisión adversarial de arquitectura. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.

Amenazas y debilidades

Threat ID	Escenario de amenaza	Weakness ID	Patrón de debilidad
CSPTF-THRT-ARC-001	Violación de invariantes de protocolo	CSPTF-WEAK-ARC-001	Invariantes no formalizados
CSPTF-THRT-ARC-002	Abuso de transiciones de estado	CSPTF-WEAK-ARC-002	Estados terminales inseguros
CSPTF-THRT-ARC-003	Compromiso de una frontera de confianza	CSPTF-WEAK-ARC-003	Acoplamiento excesivo
CSPTF-THRT-ARC-004	Actualización maliciosa o defectuosa	CSPTF-WEAK-ARC-004	Privilegios concentrados
CSPTF-THRT-ARC-005	Fallo en cascada por dependencia externa	CSPTF-WEAK-ARC-005	Recuperación arquitectónica no probada

Gate de cierre del dominio

- Aplicabilidad y exclusiones justificadas.
- Controles seleccionados con evidencia proporcional al perfil.
- Tests clasificados pass, fail, inconclusive o formally not-tested.
- Findings con owner, plazo, disclosure handling y retest.
- Dependencias críticas y riesgo residual visibles para el decision maker.

CSPTF-DOM-03 - CRY: Criptografía, aleatoriedad y material criptográfico

English: Cryptography, Randomness and Cryptographic Material

Verificar selección, implementación, uso y ciclo de vida de primitivas criptográficas, fuentes de entropía, firmas y pruebas.

Activos principales: algoritmos; parámetros; entropía; nonce; firmas; hashes; cifrado; pruebas de conocimiento cero.

Alineación de tácticas AADAPT: Credential Access, Execution, Defense Evasion, Impact, Fraud.

NIST CSF 2.0: PR.

OWASP y fuentes relacionadas: SCSTG cryptography; SCSVS cryptography.

Controles

ID	AP	Control	Requisito normativo	Evidencia esperada
CSPTF-CTRL-CRY-001	AP1	Primitivas y parámetros aprobados	La organización DEBE definir, aprobar, implementar, monitorear y revisar primitivas y parámetros aprobados, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con primitivas y parámetros aprobados.
CSPTF-CTRL-CRY-002	AP1	Generación de entropía y aleatoriedad	La organización DEBE definir, aprobar, implementar, monitorear y revisar generación de entropía y aleatoriedad, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con generación de entropía y aleatoriedad.
CSPTF-CTRL-CRY-003	AP2	Gestión segura de nonces	La organización DEBE definir, aprobar, implementar, monitorear y revisar gestión segura de nonces, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con gestión segura de nonces.
CSPTF-CTRL-CRY-004	AP2	Validación canónica de firmas	La organización DEBE definir, aprobar, implementar, monitorear y revisar validación canónica de firmas, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con validación canónica de firmas.
CSPTF-CTRL-CRY-005	AP2	Separación de dominios criptográficos	La organización DEBE definir, aprobar, implementar, monitorear y revisar separación de dominios criptográficos, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con separación de dominios criptográficos.
CSPTF-CTRL-CRY-006	AP3	Protección contra replay y malleability	La organización DEBE definir, aprobar, implementar, monitorear y revisar protección contra replay y malleability, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con protección contra replay y malleability.
CSPTF-CTRL-CRY-007	AP3	Agilidad y migración criptográfica	La organización DEBE definir, aprobar, implementar, monitorear y revisar agilidad y migración criptográfica, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con agilidad y migración criptográfica.
CSPTF-CTRL-CRY-008	AP4	Verificación de implementaciones y bibliotecas	La organización DEBE definir, aprobar, implementar, monitorear y revisar verificación	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia

ID	AP	Control	Requisito normativo	Evidencia esperada
			de implementaciones y bibliotecas, manteniendo evidencia trazable y excepciones formalmente aceptadas.	de revisión; prueba de eficacia relacionada con verificación de implementaciones y bibliotecas.

Casos de prueba autorizados

Regla de seguridad: priorizar review, laboratorio local, fork, testnet y staging. Las acciones activas de producción requieren autorización individual, monitoring, límites, stop authority y reconciliación.

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
CSPTF-TEST-CRY-001	AP1	Inventariar primitivas y parámetros	Determinar, mediante evidencia verificable y validación no destructiva, si inventariar primitivas y parámetros reduce el riesgo esperado. Revisar diseño y configuración relacionados con inventariar primitivas y parámetros, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden inventariar primitivas y parámetros. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-CRY-002	AP1	Revisar fuentes de entropía	Determinar, mediante evidencia verificable y validación no destructiva, si revisar fuentes de entropía reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar fuentes de entropía, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar fuentes de entropía. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-CRY-003	AP1	Validar generación y reutilización de nonces	Determinar, mediante evidencia verificable y validación no destructiva, si validar generación y reutilización de nonces reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar generación y reutilización de nonces, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar generación y reutilización de nonces. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-CRY-004	AP2	Comprobar validación de firmas	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar validación de firmas reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar validación de firmas, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar validación de firmas. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-CRY-005	AP2	Evaluar separación de dominios	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar separación de dominios reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar separación de dominios, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar separación de dominios. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-CRY-006	AP2	Probar controles anti-replay en entorno autorizado	Determinar, mediante evidencia verificable y validación no destructiva, si probar controles anti-	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
			validación no destructiva, si revisar fallos, revert y manejo de errores reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar fallos, revert y manejo de errores, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar fallos, revert y manejo de errores. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-SCT-007	AP2	Evaluar bucles, gas y denegación de servicio	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar bucles, gas y denegación de servicio reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar bucles, gas y denegación de servicio, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar bucles, gas y denegación de servicio. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-SCT-008	AP3	Comprobar validación de entradas y límites	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar validación de entradas y límites reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar validación de entradas y límites, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar validación de entradas y límites. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-SCT-009	AP3	Revisar eventos y observabilidad	Determinar, mediante evidencia verificable y validación no destructiva, si revisar eventos y observabilidad reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar eventos y observabilidad, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar eventos y observabilidad. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-SCT-010	AP3	Ejecutar análisis estático en laboratorio	Determinar, mediante evidencia verificable y validación no destructiva, si ejecutar análisis estático en laboratorio reduce el riesgo esperado. Revisar diseño y configuración relacionados con ejecutar análisis estático en laboratorio, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden ejecutar análisis estático en laboratorio. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-SCT-011	AP4	Ejecutar fuzzing o pruebas de propiedades en fork	Determinar, mediante evidencia verificable y validación no destructiva, si ejecutar fuzzing o pruebas de propiedades en fork reduce el riesgo esperado. Revisar diseño y configuración relacionados con ejecutar fuzzing o pruebas de propiedades en fork, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden ejecutar fuzzing o pruebas de propiedades en fork. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-SCT-012	AP4	Validar correcciones mediante revisión independiente	Determinar, mediante evidencia verificable y validación no destructiva, si validar correcciones mediante revisión independiente reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar correcciones mediante revisión independiente, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar correcciones mediante revisión independiente. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.

Amenazas y debilidades

Threat ID	Escenario de amenaza	Weakness ID	Patrón de debilidad
CSPTF-THRT-SCT-001	Ejecución no autorizada de funciones críticas	CSPTF-WEAK-SCT-001	Control de acceso incompleto
CSPTF-THRT-SCT-002	Manipulación de contabilidad interna	CSPTF-WEAK-SCT-002	Checks-effects-interactions incumplido
CSPTF-THRT-SCT-003	Reentrancia o interacción inesperada	CSPTF-WEAK-SCT-003	Aritmética o precisión incorrecta
CSPTF-THRT-SCT-004	Colisión de almacenamiento en actualización	CSPTF-WEAK-SCT-004	Upgrade inseguro
CSPTF-THRT-SCT-005	Bloqueo permanente o agotamiento de gas	CSPTF-WEAK-SCT-005	Cobertura de pruebas insuficiente

Gate de cierre del dominio

- Aplicabilidad y exclusiones justificadas.
- Controles seleccionados con evidencia proporcional al perfil.
- Tests clasificados pass, fail, inconclusive o formally not-tested.
- Findings con owner, plazo, disclosure handling y retest.
- Dependencias críticas y riesgo residual visibles para el decision maker.

CSPTF-DOM-06 - DAP: dApps, frontend, sesiones e integración de wallets

English: dApps, Frontend, Sessions and Wallet Integration

Evaluar aplicaciones cliente, sesiones, proveedores Web3, solicitudes de firma, resolución de red y controles que conectan usuarios con funciones on-chain.

Activos principales: frontend; backend BFF; wallet connectors; sesiones; deep links; firmas EIP-712; DNS/CDN; proveedores RPC.

Alineación de tácticas AADAPT: Initial Access, Execution, Credential Access, Collection, Fraud.

NIST CSF 2.0: PR, DE.

OWASP y fuentes relacionadas: SCSTG dApp and client interaction; SCSVS communications.

Controles

ID	AP	Control	Requisito normativo	Evidencia esperada
CSPTF-CTRL-DAP-001	AP1	Integridad de frontend y distribución	La organización DEBE definir, aprobar, implementar, monitorear y revisar integridad de frontend y distribución, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con integridad de frontend y distribución.
CSPTF-CTRL-DAP-002	AP1	Vinculación segura de sesión y wallet	La organización DEBE definir, aprobar, implementar, monitorear y revisar vinculación segura de sesión y wallet, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con vinculación segura de sesión y wallet.
CSPTF-CTRL-DAP-003	AP2	Presentación clara de solicitudes de firma	La organización DEBE definir, aprobar, implementar, monitorear y revisar presentación clara de solicitudes de firma, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con presentación clara de solicitudes de firma.
CSPTF-CTRL-DAP-004	AP2	Validación de red, cadena y contrato	La organización DEBE definir, aprobar, implementar, monitorear y revisar validación de red, cadena y contrato, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con validación de red, cadena y contrato.
CSPTF-CTRL-DAP-005	AP2	Autenticación y autorización off-chain	La organización DEBE definir, aprobar, implementar, monitorear y revisar autenticación y autorización off-chain, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con autenticación y autorización off-chain.
CSPTF-CTRL-DAP-006	AP3	Protección de APIs y secretos de cliente	La organización DEBE definir, aprobar, implementar, monitorear y revisar protección de apis y secretos de cliente, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con protección de apis y secretos de cliente.
CSPTF-CTRL-DAP-007	AP3	Seguridad de contenido, DNS y dependencias	La organización DEBE definir, aprobar, implementar, monitorear y revisar seguridad de contenido, dns y dependencias, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con seguridad de contenido, dns y dependencias.
CSPTF-CTRL-DAP-008	AP4	Detección de manipulación y respuesta	La organización DEBE definir, aprobar,	Política o diseño aprobado; configuración o

ID	AP	Control	Requisito normativo	Evidencia esperada
			implementar, monitorear y revisar detección de manipulación y respuesta, manteniendo evidencia trazable y excepciones formalmente aceptadas.	artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con detección de manipulación y respuesta.

Casos de prueba autorizados

Regla de seguridad: priorizar review, laboratorio local, fork, testnet y staging. Las acciones activas de producción requieren autorización individual, monitoring, límites, stop authority y reconciliación.

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
CSPTF-TEST-DAP-001	AP1	Revisar integridad del artefacto frontend	Determinar, mediante evidencia verificable y validación no destructiva, si revisar integridad del artefacto frontend reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar integridad del artefacto frontend, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar integridad del artefacto frontend. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-DAP-002	AP1	Validar vinculación de cuenta, sesión y wallet	Determinar, mediante evidencia verificable y validación no destructiva, si validar vinculación de cuenta, sesión y wallet reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar vinculación de cuenta, sesión y wallet, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar vinculación de cuenta, sesión y wallet. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-DAP-003	AP1	Evaluar mensajes y transacciones solicitadas	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar mensajes y transacciones solicitadas reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar mensajes y transacciones solicitadas, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar mensajes y transacciones solicitadas. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-DAP-004	AP2	Comprobar chain ID, contrato y red objetivo	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar chain id, contrato y red objetivo reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar chain id, contrato y red objetivo, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar chain id, contrato y red objetivo. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-DAP-005	AP2	Revisar autenticación y autorización off-chain	Determinar, mediante evidencia verificable y validación no destructiva, si revisar autenticación y autorización off-chain reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar autenticación y autorización off-chain, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar autenticación y autorización off-chain. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
CSPTF-TEST-DAP-006	AP2	Evaluar exposición de secretos y configuración	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar exposición de secretos y configuración reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar exposición de secretos y configuración, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar exposición de secretos y configuración. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-DAP-007	AP2	Comprobar protección contra inyección y XSS	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar protección contra inyección y xss reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar protección contra inyección y xss, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar protección contra inyección y xss. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-DAP-008	AP3	Revisar dependencias, CDN y carga remota	Determinar, mediante evidencia verificable y validación no destructiva, si revisar dependencias, cdn y carga remota reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar dependencias, cdn y carga remota, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar dependencias, cdn y carga remota. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-DAP-009	AP3	Validar deep links y redirecciones	Determinar, mediante evidencia verificable y validación no destructiva, si validar deep links y redirecciones reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar deep links y redirecciones, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar deep links y redirecciones. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-DAP-010	AP3	Evaluar disponibilidad y confianza del RPC	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar disponibilidad y confianza del rpc reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar disponibilidad y confianza del rpc, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar disponibilidad y confianza del rpc. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-DAP-011	AP4	Simular manipulación de interfaz en laboratorio	Determinar, mediante evidencia verificable y validación no destructiva, si simular manipulación de interfaz en laboratorio reduce el riesgo esperado. Revisar diseño y configuración relacionados con simular manipulación de interfaz en laboratorio, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden simular manipulación de interfaz en laboratorio. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-DAP-012	AP4	Comprobar detección y revocación de sesiones	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar detección y revocación de sesiones reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar detección y revocación de sesiones, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar detección y revocación de sesiones. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.

Amenazas y debilidades

Threat ID	Escenario de amenaza	Weakness ID	Patrón de debilidad
CSPTF-THRT-DAP-001	Manipulación de interfaz para desviar fondos	CSPTF-WEAK-DAP-001	Firmas ciegas
CSPTF-THRT-DAP-002	Firma engañosa o autorización excesiva	CSPTF-WEAK-DAP-002	Chain ID no validado
CSPTF-THRT-DAP-003	Secuestro de sesión vinculada a wallet	CSPTF-WEAK-DAP-003	Sesiones no ligadas al firmante
CSPTF-THRT-DAP-004	Sustitución de RPC, red o contrato	CSPTF-WEAK-DAP-004	Dependencias remotas sin integridad
CSPTF-THRT-DAP-005	Compromiso de dominio o cadena de distribución	CSPTF-WEAK-DAP-005	Mensajes de riesgo poco comprensibles

Gate de cierre del dominio

- Aplicabilidad y exclusiones justificadas.
- Controles seleccionados con evidencia proporcional al perfil.
- Tests clasificados pass, fail, inconclusive o formally not-tested.
- Findings con owner, plazo, disclosure handling y retest.
- Dependencias críticas y riesgo residual visibles para el decision maker.

CSPTF-DOM-07 - TOK: Tokens, NFT y ciclo de vida de activos

English: Tokens, NFTs and Asset Lifecycle

Evaluar emisión, quema, transferencia, metadata, permisos, supply, interoperabilidad y ciclo de vida de activos fungibles y no fungibles.

Activos principales: token contracts; NFT collections; metadata; minting; burning; royalties; allowances; bridged assets.

Alineación de tácticas AADAPT: Execution, Privilege Escalation, Impact, Fraud.

NIST CSF 2.0: PR, DE.

OWASP y fuentes relacionadas: SCSTG token interactions; SCSVS business logic.

Controles

ID	AP	Control	Requisito normativo	Evidencia esperada
CSPTF-CTRL-TOK-001	AP1	Modelo de emisión y supply	La organización DEBE definir, aprobar, implementar, monitorear y revisar modelo de emisión y supply, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con modelo de emisión y supply.
CSPTF-CTRL-TOK-002	AP1	Autorización de mint y burn	La organización DEBE definir, aprobar, implementar, monitorear y revisar autorización de mint y burn, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con autorización de mint y burn.
CSPTF-CTRL-TOK-003	AP2	Transferencias, hooks y callbacks	La organización DEBE definir, aprobar, implementar, monitorear y revisar transferencias, hooks y callbacks, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con transferencias, hooks y callbacks.
CSPTF-CTRL-TOK-004	AP2	Allowances, approvals y permisos	La organización DEBE definir, aprobar, implementar, monitorear y revisar allowances, approvals y permisos, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con allowances, approvals y permisos.
CSPTF-CTRL-TOK-005	AP2	Metadata y contenido direccionable	La organización DEBE definir, aprobar, implementar, monitorear y revisar metadata y contenido direccionable, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con metadata y contenido direccionable.
CSPTF-CTRL-TOK-006	AP3	Compatibilidad e interoperabilidad	La organización DEBE definir, aprobar, implementar, monitorear y revisar compatibilidad e interoperabilidad, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con compatibilidad e interoperabilidad.
CSPTF-CTRL-TOK-007	AP3	Administración, pausa y recuperación	La organización DEBE definir, aprobar, implementar, monitorear y revisar administración, pausa y recuperación, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con administración, pausa y recuperación.
CSPTF-CTRL-TOK-008	AP4	Monitoreo de anomalías del activo	La organización DEBE definir, aprobar,	Política o diseño aprobado; configuración o

ID	AP	Control	Requisito normativo	Evidencia esperada
			implementar, monitorear y revisar monitoreo de anomalías del activo, manteniendo evidencia trazable y excepciones formalmente aceptadas.	artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con monitoreo de anomalías del activo.

Casos de prueba autorizados

Regla de seguridad: priorizar review, laboratorio local, fork, testnet y staging. Las acciones activas de producción requieren autorización individual, monitoring, límites, stop authority y reconciliación.

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
CSPTF-TEST-TOK-001	AP1	Validar invariantes de supply	Determinar, mediante evidencia verificable y validación no destructiva, si validar invariantes de supply reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar invariantes de supply, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar invariantes de supply. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-TOK-002	AP1	Revisar permisos de mint y burn	Determinar, mediante evidencia verificable y validación no destructiva, si revisar permisos de mint y burn reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar permisos de mint y burn, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar permisos de mint y burn. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-TOK-003	AP1	Evaluar transferencias y callbacks	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar transferencias y callbacks reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar transferencias y callbacks, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar transferencias y callbacks. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-TOK-004	AP2	Comprobar approvals y allowances	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar approvals y allowances reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar approvals y allowances, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar approvals y allowances. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-TOK-005	AP2	Revisar metadata, URI y mutabilidad	Determinar, mediante evidencia verificable y validación no destructiva, si revisar metadata, uri y mutabilidad reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar metadata, uri y mutabilidad, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar metadata, uri y mutabilidad. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-TOK-006	AP2	Validar royalties y lógica comercial	Determinar, mediante evidencia verificable y validación no destructiva, si validar royalties y	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
			lógica comercial reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar royalties y lógica comercial, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	eficacia y no se identifican rutas razonables que invaliden validar royalties y lógica comercial. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-TOK-007	AP2	Comprobar compatibilidad con estándares	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar compatibilidad con estándares reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar compatibilidad con estándares, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar compatibilidad con estándares. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-TOK-008	AP3	Evaluar tokens con comportamientos no convencionales	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar tokens con comportamientos no convencionales reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar tokens con comportamientos no convencionales, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar tokens con comportamientos no convencionales. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-TOK-009	AP3	Revisar administración y pausas	Determinar, mediante evidencia verificable y validación no destructiva, si revisar administración y pausas reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar administración y pausas, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar administración y pausas. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-TOK-010	AP3	Validar migración o reemplazo del activo	Determinar, mediante evidencia verificable y validación no destructiva, si validar migración o reemplazo del activo reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar migración o reemplazo del activo, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar migración o reemplazo del activo. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-TOK-011	AP4	Analizar representación bridged o wrapped	Determinar, mediante evidencia verificable y validación no destructiva, si analizar representación bridged o wrapped reduce el riesgo esperado. Revisar diseño y configuración relacionados con analizar representación bridged o wrapped, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden analizar representación bridged o wrapped. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-TOK-012	AP4	Comprobar monitoreo de emisión anómala	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar monitoreo de emisión anómala reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar monitoreo de emisión anómala, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar monitoreo de emisión anómala. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.

Amenazas y debilidades

Threat ID	Escenario de amenaza	Weakness ID	Patrón de debilidad
CSPTF-THRT-TOK-001	Emisión no autorizada o ilimitada	CSPTF-WEAK-TOK-001	Supply no acotado
CSPTF-THRT-TOK-002	Robo mediante approval excesivo	CSPTF-WEAK-TOK-002	Metadata centralizada y mutable
CSPTF-THRT-TOK-003	Manipulación o desaparición de metadata	CSPTF-WEAK-TOK-003	Hooks no confiables
CSPTF-THRT-TOK-004	Incompatibilidad que bloquea activos	CSPTF-WEAK-TOK-004	Permisos de minter excesivos
CSPTF-THRT-TOK-005	Duplicación o desanclaje de activo wrapped	CSPTF-WEAK-TOK-005	Semántica de transferencia no estándar

Gate de cierre del dominio

- Aplicabilidad y exclusiones justificadas.
- Controles seleccionados con evidencia proporcional al perfil.
- Tests clasificados pass, fail, inconclusive o formally not-tested.
- Findings con owner, plazo, disclosure handling y retest.
- Dependencias críticas y riesgo residual visibles para el decision maker.

CSPTF-DOM-08 - DEF: DeFi y seguridad económica

English: DeFi and Economic Security

Evaluar solvencia, precios, incentivos, liquidaciones, AMM, préstamos, vaults, MEV y ataques de composición económica.

Activos principales: pools; AMM; lending markets; vaults; liquidation bots; governance tokens; collateral; fee models.

Alineación de tácticas AADAPT: Execution, Impact, Fraud.

NIST CSF 2.0: ID, PR, DE.

OWASP y fuentes relacionadas: SCSTG DeFi and economic testing; SCSVS business logic.

Controles

ID	AP	Control	Requisito normativo	Evidencia esperada
CSPTF-CTRL-DEF-001	AP1	Invariantes económicas y solvencia	La organización DEBE definir, aprobar, implementar, monitorear y revisar invariantes económicas y solvencia, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con invariantes económicas y solvencia.
CSPTF-CTRL-DEF-002	AP1	Modelos de precio y deslizamiento	La organización DEBE definir, aprobar, implementar, monitorear y revisar modelos de precio y deslizamiento, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con modelos de precio y deslizamiento.
CSPTF-CTRL-DEF-003	AP2	Colateralización y liquidación	La organización DEBE definir, aprobar, implementar, monitorear y revisar colateralización y liquidación, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con colateralización y liquidación.
CSPTF-CTRL-DEF-004	AP2	Resistencia a manipulación temporal	La organización DEBE definir, aprobar, implementar, monitorear y revisar resistencia a manipulación temporal, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con resistencia a manipulación temporal.
CSPTF-CTRL-DEF-005	AP2	Límites, caps y circuit breakers	La organización DEBE definir, aprobar, implementar, monitorear y revisar límites, caps y circuit breakers, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con límites, caps y circuit breakers.
CSPTF-CTRL-DEF-006	AP3	Contabilidad de fees, shares y rewards	La organización DEBE definir, aprobar, implementar, monitorear y revisar contabilidad de fees, shares y rewards, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con contabilidad de fees, shares y rewards.
CSPTF-CTRL-DEF-007	AP3	Riesgo de composabilidad y dependencia	La organización DEBE definir, aprobar, implementar, monitorear y revisar riesgo de composabilidad y dependencia, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con riesgo de composabilidad y dependencia.
CSPTF-CTRL-DEF-008	AP4	Simulación económica y monitoreo	La organización DEBE definir, aprobar,	Política o diseño aprobado; configuración o

ID	AP	Control	Requisito normativo	Evidencia esperada
			implementar, monitorear y revisar simulación económica y monitoreo, manteniendo evidencia trazable y excepciones formalmente aceptadas.	artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con simulación económica y monitoreo.

Casos de prueba autorizados

Regla de seguridad: priorizar review, laboratorio local, fork, testnet y staging. Las acciones activas de producción requieren autorización individual, monitoring, límites, stop authority y reconciliación.

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
CSPTF-TEST-DEF-001	AP1	Modelar invariantes económicas	Determinar, mediante evidencia verificable y validación no destructiva, si modelar invariantes económicas reduce el riesgo esperado. Revisar diseño y configuración relacionados con modelar invariantes económicas, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden modelar invariantes económicas. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-DEF-002	AP1	Validar valoración de activos y shares	Determinar, mediante evidencia verificable y validación no destructiva, si validar valoración de activos y shares reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar valoración de activos y shares, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar valoración de activos y shares. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-DEF-003	AP1	Evaluar colateral y factores de liquidación	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar colateral y factores de liquidación reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar colateral y factores de liquidación, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar colateral y factores de liquidación. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-DEF-004	AP2	Comprobar exposición a flash liquidity	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar exposición a flash liquidity reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar exposición a flash liquidity, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar exposición a flash liquidity. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-DEF-005	AP2	Analizar slippage, profundidad y concentración	Determinar, mediante evidencia verificable y validación no destructiva, si analizar slippage, profundidad y concentración reduce el riesgo esperado. Revisar diseño y configuración relacionados con analizar slippage, profundidad y concentración, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden analizar slippage, profundidad y concentración. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-DEF-006	AP2	Revisar caps, pausas y límites dinámicos	Determinar, mediante evidencia verificable y	PASS: Existe diseño aprobado, la implementación

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
			validación no destructiva, si revisar caps, pausas y límites dinámicos reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar caps, pausas y límites dinámicos, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar caps, pausas y límites dinámicos. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-DEF-007	AP2	Evaluar redondeo, precisión y acumulación de fees	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar redondeo, precisión y acumulación de fees reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar redondeo, precisión y acumulación de fees, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar redondeo, precisión y acumulación de fees. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-DEF-008	AP3	Comprobar incentivos y ataques de gobernanza económica	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar incentivos y ataques de gobernanza económica reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar incentivos y ataques de gobernanza económica, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar incentivos y ataques de gobernanza económica. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-DEF-009	AP3	Analizar MEV, ordenamiento y sandwich risk	Determinar, mediante evidencia verificable y validación no destructiva, si analizar mev, ordenamiento y sandwich risk reduce el riesgo esperado. Revisar diseño y configuración relacionados con analizar mev, ordenamiento y sandwich risk, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden analizar mev, ordenamiento y sandwich risk. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-DEF-010	AP3	Ejecutar simulaciones históricas y de estrés	Determinar, mediante evidencia verificable y validación no destructiva, si ejecutar simulaciones históricas y de estrés reduce el riesgo esperado. Revisar diseño y configuración relacionados con ejecutar simulaciones históricas y de estrés, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden ejecutar simulaciones históricas y de estrés. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-DEF-011	AP4	Validar insolvencia y socialización de pérdidas	Determinar, mediante evidencia verificable y validación no destructiva, si validar insolvencia y socialización de pérdidas reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar insolvencia y socialización de pérdidas, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar insolvencia y socialización de pérdidas. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-DEF-012	AP4	Comprobar alertas de manipulación económica	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar alertas de manipulación económica reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar alertas de manipulación económica, contrastarlos con	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar alertas de manipulación económica. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
			invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	reproducible en entorno autorizado o dependencia no tratada.

Amenazas y debilidades

Threat ID	Escenario de amenaza	Weakness ID	Patrón de debilidad
CSPTF-THRT-DEF-001	Manipulación de precio y extracción de valor	CSPTF-WEAK-DEF-001	Oráculo poco robusto
CSPTF-THRT-DEF-002	Insolvencia por liquidaciones fallidas	CSPTF-WEAK-DEF-002	Caps inexistentes
CSPTF-THRT-DEF-003	Ataque de liquidez temporal	CSPTF-WEAK-DEF-003	Supuestos de liquidez irreales
CSPTF-THRT-DEF-004	Drenaje por error de contabilidad de shares	CSPTF-WEAK-DEF-004	Redondeo acumulativo
CSPTF-THRT-DEF-005	Captura de gobernanza económica	CSPTF-WEAK-DEF-005	Dependencia de una sola ruta de liquidación

Gate de cierre del dominio

- Aplicabilidad y exclusiones justificadas.
- Controles seleccionados con evidencia proporcional al perfil.
- Tests clasificados pass, fail, inconclusive o formally not-tested.
- Findings con owner, plazo, disclosure handling y retest.
- Dependencias críticas y riesgo residual visibles para el decision maker.

CSPTF-DOM-09 - ORA: Oráculos, datos externos y automatización

English: Oracles, External Data and Automation

Evaluar autenticidad, frescura, disponibilidad, agregación y uso seguro de precios, datos, keepers y automatizaciones off-chain.

Activos principales: price feeds; data providers; keepers; relayers; webhooks; time sources; fallbacks; aggregation logic.

Alineación de tácticas AADAPT: Execution, Defense Evasion, Impact, Fraud.

NIST CSF 2.0: PR, DE, RS.

OWASP y fuentes relacionadas: SCSTG oracle security; SCSVS oracle controls.

Controles

ID	AP	Control	Requisito normativo	Evidencia esperada
CSPTF-CTRL-ORA-001	AP1	Diversidad y gobernanza de fuentes	La organización DEBE definir, aprobar, implementar, monitorear y revisar diversidad y gobernanza de fuentes, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con diversidad y gobernanza de fuentes.
CSPTF-CTRL-ORA-002	AP1	Frescura, heartbeat y staleness	La organización DEBE definir, aprobar, implementar, monitorear y revisar frescura, heartbeat y staleness, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con frescura, heartbeat y staleness.
CSPTF-CTRL-ORA-003	AP2	Agregación y tolerancia a outliers	La organización DEBE definir, aprobar, implementar, monitorear y revisar agregación y tolerancia a outliers, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con agregación y tolerancia a outliers.
CSPTF-CTRL-ORA-004	AP2	Autenticidad e integridad de datos	La organización DEBE definir, aprobar, implementar, monitorear y revisar autenticidad e integridad de datos, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con autenticidad e integridad de datos.
CSPTF-CTRL-ORA-005	AP2	Fallbacks y degradación segura	La organización DEBE definir, aprobar, implementar, monitorear y revisar fallbacks y degradación segura, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con fallbacks y degradación segura.
CSPTF-CTRL-ORA-006	AP3	Seguridad de keepers y automatización	La organización DEBE definir, aprobar, implementar, monitorear y revisar seguridad de keepers y automatización, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con seguridad de keepers y automatización.
CSPTF-CTRL-ORA-007	AP3	Límites de uso y sanity checks	La organización DEBE definir, aprobar, implementar, monitorear y revisar límites de uso y sanity checks, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con límites de uso y sanity checks.
CSPTF-CTRL-ORA-008	AP4	Monitoreo y respuesta de oráculos	La organización DEBE definir, aprobar, implementar, monitorear y revisar monitoreo y respuesta de oráculos, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con monitoreo y respuesta de oráculos.

Casos de prueba autorizados

Regla de seguridad: priorizar review, laboratorio local, fork, testnet y staging. Las acciones activas de producción requieren autorización individual, monitoring, límites, stop authority y reconciliación.

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
CSPTF-TEST-ORA-001	AP1	Inventariar fuentes y dependencias	Determinar, mediante evidencia verificable y validación no destructiva, si inventariar fuentes y dependencias reduce el riesgo esperado. Revisar diseño y configuración relacionados con inventariar fuentes y dependencias, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden inventariar fuentes y dependencias. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-ORA-002	AP1	Validar frescura y heartbeat	Determinar, mediante evidencia verificable y validación no destructiva, si validar frescura y heartbeat reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar frescura y heartbeat, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar frescura y heartbeat. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-ORA-003	AP1	Evaluar agregación y outliers	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar agregación y outliers reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar agregación y outliers, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar agregación y outliers. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-ORA-004	AP2	Comprobar autenticidad de actualizaciones	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar autenticidad de actualizaciones reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar autenticidad de actualizaciones, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar autenticidad de actualizaciones. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-ORA-005	AP2	Revisar límites y sanity checks	Determinar, mediante evidencia verificable y validación no destructiva, si revisar límites y sanity checks reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar límites y sanity checks, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar límites y sanity checks. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-ORA-006	AP2	Evaluar fallbacks y modo degradado	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar fallbacks y modo degradado reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar fallbacks y modo degradado, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar fallbacks y modo degradado. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
CSPTF-TEST-ORA-007	AP2	Comprobar permisos de actualización	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar permisos de actualización reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar permisos de actualización, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar permisos de actualización. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-ORA-008	AP3	Revisar keepers, jobs y secretos	Determinar, mediante evidencia verificable y validación no destructiva, si revisar keepers, jobs y secretos reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar keepers, jobs y secretos, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar keepers, jobs y secretos. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-ORA-009	AP3	Simular indisponibilidad de fuente	Determinar, mediante evidencia verificable y validación no destructiva, si simular indisponibilidad de fuente reduce el riesgo esperado. Revisar diseño y configuración relacionados con simular indisponibilidad de fuente, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden simular indisponibilidad de fuente. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-ORA-010	AP3	Evaluar manipulación de mercado subyacente	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar manipulación de mercado subyacente reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar manipulación de mercado subyacente, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar manipulación de mercado subyacente. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-ORA-011	AP4	Comprobar observabilidad y alertas	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar observabilidad y alertas reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar observabilidad y alertas, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar observabilidad y alertas. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-ORA-012	AP4	Validar recuperación tras datos incorrectos	Determinar, mediante evidencia verificable y validación no destructiva, si validar recuperación tras datos incorrectos reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar recuperación tras datos incorrectos, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar recuperación tras datos incorrectos. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.

Amenazas y debilidades

Threat ID	Escenario de amenaza	Weakness ID	Patrón de debilidad
CSPTF-THRT-ORA-001	Manipulación de feed	CSPTF-WEAK-ORA-001	Fuente única

Threat ID	Escenario de amenaza	Weakness ID	Patrón de debilidad
CSPTF-THRT-ORA-002	Uso de datos obsoletos	CSPTF-WEAK-ORA-002	Staleness no controlado
CSPTF-THRT-ORA-003	Compromiso de updater o keeper	CSPTF-WEAK-ORA-003	Agregación débil
CSPTF-THRT-ORA-004	Indisponibilidad coordinada de fuentes	CSPTF-WEAK-ORA-004	Fallback inseguro
CSPTF-THRT-ORA-005	Desviación de mercado de referencia	CSPTF-WEAK-ORA-005	Límites de precio ausentes

Gate de cierre del dominio

- Aplicabilidad y exclusiones justificadas.
- Controles seleccionados con evidencia proporcional al perfil.
- Tests clasificados pass, fail, inconclusive o formally not-tested.
- Findings con owner, plazo, disclosure handling y retest.
- Dependencias críticas y riesgo residual visibles para el decision maker.

CSPTF-DOM-10 - BRG: Bridges, cross-chain e interoperabilidad

English: Bridges, Cross-chain and Interoperability

Evaluar bloqueo, mint, burn, release, validación de mensajes, relayers, verificadores, finalidad y coherencia entre dominios.

Activos principales: bridge contracts; validators; relayers; light clients; message queues; wrapped assets; proofs; source/destination chains.

Alineación de tácticas AADAPT: Initial Access, Execution, Credential Access, Impact, Fraud.

NIST CSF 2.0: ID, PR, DE, RS.

OWASP y fuentes relacionadas: SCSTG cross-contract and cross-chain interactions.

Controles

ID	AP	Control	Requisito normativo	Evidencia esperada
CSPTF-CTRL-BRG-001	AP1	Modelo de confianza cross-chain	La organización DEBE definir, aprobar, implementar, monitorear y revisar modelo de confianza cross-chain, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con modelo de confianza cross-chain.
CSPTF-CTRL-BRG-002	AP1	Autenticidad y unicidad de mensajes	La organización DEBE definir, aprobar, implementar, monitorear y revisar autenticidad y unicidad de mensajes, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con autenticidad y unicidad de mensajes.
CSPTF-CTRL-BRG-003	AP2	Finalidad y manejo de reorganizaciones	La organización DEBE definir, aprobar, implementar, monitorear y revisar finalidad y manejo de reorganizaciones, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con finalidad y manejo de reorganizaciones.
CSPTF-CTRL-BRG-004	AP2	Custodia y respaldo de activos	La organización DEBE definir, aprobar, implementar, monitorear y revisar custodia y respaldo de activos, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con custodia y respaldo de activos.
CSPTF-CTRL-BRG-005	AP2	Validadores, relayers y quorum	La organización DEBE definir, aprobar, implementar, monitorear y revisar validadores, relayers y quorum, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con validadores, relayers y quorum.
CSPTF-CTRL-BRG-006	AP3	Coherencia semántica entre cadenas	La organización DEBE definir, aprobar, implementar, monitorear y revisar coherencia semántica entre cadenas, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con coherencia semántica entre cadenas.
CSPTF-CTRL-BRG-007	AP3	Rate limits, caps y pausas	La organización DEBE definir, aprobar, implementar, monitorear y revisar rate limits, caps y pausas, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con rate limits, caps y pausas.
CSPTF-CTRL-BRG-008	AP4	Monitoreo y reconciliación cross-chain	La organización DEBE definir, aprobar, implementar, monitorear y revisar monitoreo y	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia

ID	AP	Control	Requisito normativo	Evidencia esperada
			reconciliación cross-chain, manteniendo evidencia trazable y excepciones formalmente aceptadas.	de revisión; prueba de eficacia relacionada con monitoreo y reconciliación cross-chain.

Casos de prueba autorizados

Regla de seguridad: priorizar review, laboratorio local, fork, testnet y staging. Las acciones activas de producción requieren autorización individual, monitoring, límites, stop authority y reconciliación.

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
CSPTF-TEST-BRG-001	AP1	Documentar modelo de confianza del bridge	Determinar, mediante evidencia verificable y validación no destructiva, si documentar modelo de confianza del bridge reduce el riesgo esperado. Revisar diseño y configuración relacionados con documentar modelo de confianza del bridge, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden documentar modelo de confianza del bridge. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-BRG-002	AP1	Validar autenticidad de mensajes	Determinar, mediante evidencia verificable y validación no destructiva, si validar autenticidad de mensajes reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar autenticidad de mensajes, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar autenticidad de mensajes. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-BRG-003	AP1	Comprobar nonce, replay y unicidad	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar nonce, replay y unicidad reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar nonce, replay y unicidad, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar nonce, replay y unicidad. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-BRG-004	AP2	Evaluar finalidad y reorganizaciones	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar finalidad y reorganizaciones reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar finalidad y reorganizaciones, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar finalidad y reorganizaciones. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-BRG-005	AP2	Revisar lock-mint y burn-release	Determinar, mediante evidencia verificable y validación no destructiva, si revisar lock-mint y burn-release reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar lock-mint y burn-release, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar lock-mint y burn-release. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-BRG-006	AP2	Comprobar quorum y rotación de validadores	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar quorum y	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
			rotación de validadores reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar quorum y rotación de validadores, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	eficacia y no se identifican rutas razonables que invaliden comprobar quorum y rotación de validadores. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-BRG-007	AP2	Evaluar coherencia entre contratos de ambos lados	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar coherencia entre contratos de ambos lados reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar coherencia entre contratos de ambos lados, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar coherencia entre contratos de ambos lados. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-BRG-008	AP3	Revisar proof verification o light client	Determinar, mediante evidencia verificable y validación no destructiva, si revisar proof verification o light client reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar proof verification o light client, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar proof verification o light client. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-BRG-009	AP3	Validar caps, rate limits y pausas	Determinar, mediante evidencia verificable y validación no destructiva, si validar caps, rate limits y pausas reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar caps, rate limits y pausas, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar caps, rate limits y pausas. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-BRG-010	AP3	Ejecutar reconciliación de supply y reservas	Determinar, mediante evidencia verificable y validación no destructiva, si ejecutar reconciliación de supply y reservas reduce el riesgo esperado. Revisar diseño y configuración relacionados con ejecutar reconciliación de supply y reservas, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden ejecutar reconciliación de supply y reservas. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-BRG-011	AP4	Simular fallo de relayer o cadena	Determinar, mediante evidencia verificable y validación no destructiva, si simular fallo de relayer o cadena reduce el riesgo esperado. Revisar diseño y configuración relacionados con simular fallo de relayer o cadena, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden simular fallo de relayer o cadena. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-BRG-012	AP4	Comprobar monitoreo y respuesta cross-chain	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar monitoreo y respuesta cross-chain reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar monitoreo y respuesta cross-chain, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar monitoreo y respuesta cross-chain. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.

Amenazas y debilidades

Threat ID	Escenario de amenaza	Weakness ID	Patrón de debilidad
CSPTF-THRT-BRG-001	Falsificación o replay de mensaje cross-chain	CSPTF-WEAK-BRG-001	Dominio de mensaje ambiguo
CSPTF-THRT-BRG-002	Compromiso del quorum de validadores	CSPTF-WEAK-BRG-002	Quorum concentrado
CSPTF-THRT-BRG-003	Mint sin respaldo o release duplicado	CSPTF-WEAK-BRG-003	Reconciliación insuficiente
CSPTF-THRT-BRG-004	Fallo por reorganización o finalidad	CSPTF-WEAK-BRG-004	Finalidad asumida incorrectamente
CSPTF-THRT-BRG-005	Inconsistencia lógica entre cadenas	CSPTF-WEAK-BRG-005	Rate limits ausentes

Gate de cierre del dominio

- Aplicabilidad y exclusiones justificadas.
- Controles seleccionados con evidencia proporcional al perfil.
- Tests clasificados pass, fail, inconclusive o formally not-tested.
- Findings con owner, plazo, disclosure handling y retest.
- Dependencias críticas y riesgo residual visibles para el decision maker.

CSPTF-DOM-11 - NET: Consenso, validadores, nodos y redes P2P

English: Consensus, Validators, Nodes and P2P Networks

Evaluar seguridad del consenso, operación de nodos, validadores, clientes, mempool, P2P, sincronización y exposición de interfaces.

Activos principales: validators; full nodes; consensus clients; execution clients; mempool; P2P network; genesis/config; peer discovery.

Alineación de tácticas AADAPT: Resource Development, Initial Access, Execution, Lateral Movement, Impact.

NIST CSF 2.0: PR, DE, RC.

OWASP y fuentes relacionadas: OWASP scope is partial; CSPTF extension.

Controles

ID	AP	Control	Requisito normativo	Evidencia esperada
CSPTF-CTRL-NET-001	AP1	Configuración de consenso y génesis	La organización DEBE definir, aprobar, implementar, monitorear y revisar configuración de consenso y génesis, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con configuración de consenso y génesis.
CSPTF-CTRL-NET-002	AP1	Diversidad y endurecimiento de clientes	La organización DEBE definir, aprobar, implementar, monitorear y revisar diversidad y endurecimiento de clientes, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con diversidad y endurecimiento de clientes.
CSPTF-CTRL-NET-003	AP2	Gestión de identidades de validador	La organización DEBE definir, aprobar, implementar, monitorear y revisar gestión de identidades de validador, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con gestión de identidades de validador.
CSPTF-CTRL-NET-004	AP2	Seguridad P2P y peer management	La organización DEBE definir, aprobar, implementar, monitorear y revisar seguridad p2p y peer management, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con seguridad p2p y peer management.
CSPTF-CTRL-NET-005	AP2	Mempool y propagación de transacciones	La organización DEBE definir, aprobar, implementar, monitorear y revisar mempool y propagación de transacciones, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con mempool y propagación de transacciones.
CSPTF-CTRL-NET-006	AP3	Sincronización, checkpoints y estado	La organización DEBE definir, aprobar, implementar, monitorear y revisar sincronización, checkpoints y estado, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con sincronización, checkpoints y estado.
CSPTF-CTRL-NET-007	AP3	Protección contra slashing y equivocación	La organización DEBE definir, aprobar, implementar, monitorear y revisar protección contra slashing y equivocación, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con protección contra slashing y equivocación.

ID	AP	Control	Requisito normativo	Evidencia esperada
CSPTF-CTRL-NET-008	AP4	Monitoreo, disponibilidad y recuperación	La organización DEBE definir, aprobar, implementar, monitorear y revisar monitoreo, disponibilidad y recuperación, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con monitoreo, disponibilidad y recuperación.

Casos de prueba autorizados

Regla de seguridad: priorizar review, laboratorio local, fork, testnet y staging. Las acciones activas de producción requieren autorización individual, monitoring, límites, stop authority y reconciliación.

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
CSPTF-TEST-NET-001	AP1	Revisar parámetros de consenso y génesis	Determinar, mediante evidencia verificable y validación no destructiva, si revisar parámetros de consenso y génesis reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar parámetros de consenso y génesis, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar parámetros de consenso y génesis. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-NET-002	AP1	Validar diversidad y versiones de clientes	Determinar, mediante evidencia verificable y validación no destructiva, si validar diversidad y versiones de clientes reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar diversidad y versiones de clientes, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar diversidad y versiones de clientes. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-NET-003	AP1	Evaluar exposición de nodos y puertos	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar exposición de nodos y puertos reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar exposición de nodos y puertos, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar exposición de nodos y puertos. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-NET-004	AP2	Comprobar peer discovery y allowlisting	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar peer discovery y allowlisting reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar peer discovery y allowlisting, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar peer discovery y allowlisting. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-NET-005	AP2	Revisar identidad y claves de validador	Determinar, mediante evidencia verificable y validación no destructiva, si revisar identidad y claves de validador reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar identidad y claves de validador, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar identidad y claves de validador. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
CSPTF-TEST-NET-006	AP2	Evaluar protección contra double signing	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar protección contra double signing reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar protección contra double signing, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar protección contra double signing. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-NET-007	AP2	Comprobar mempool y políticas de admisión	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar mempool y políticas de admisión reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar mempool y políticas de admisión, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar mempool y políticas de admisión. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-NET-008	AP3	Validar sincronización y checkpoints	Determinar, mediante evidencia verificable y validación no destructiva, si validar sincronización y checkpoints reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar sincronización y checkpoints, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar sincronización y checkpoints. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-NET-009	AP3	Evaluar resistencia a particiones en laboratorio	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar resistencia a particiones en laboratorio reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar resistencia a particiones en laboratorio, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar resistencia a particiones en laboratorio. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-NET-010	AP3	Revisar límites de recursos y DoS	Determinar, mediante evidencia verificable y validación no destructiva, si revisar límites de recursos y dos reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar límites de recursos y dos, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar límites de recursos y dos. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-NET-011	AP4	Comprobar backups y reconstrucción de estado	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar backups y reconstrucción de estado reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar backups y reconstrucción de estado, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar backups y reconstrucción de estado. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-NET-012	AP4	Ejecutar simulación de indisponibilidad de validador	Determinar, mediante evidencia verificable y validación no destructiva, si ejecutar simulación de indisponibilidad de validador reduce el riesgo esperado. Revisar diseño y configuración relacionados con ejecutar simulación de indisponibilidad de validador, contrastarlos con invariantes y requisitos, y validar su eficacia	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden ejecutar simulación de indisponibilidad de validador. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
			mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	no tratada.

Amenazas y debilidades

Threat ID	Escenario de amenaza	Weakness ID	Patrón de debilidad
CSPTF-THRT-NET-001	Partición o eclipse de nodos	CSPTF-WEAK-NET-001	Puertos administrativos expuestos
CSPTF-THRT-NET-002	Compromiso de validador	CSPTF-WEAK-NET-002	Clientes sin diversidad
CSPTF-THRT-NET-003	Double signing o slashing	CSPTF-WEAK-NET-003	Protección anti-slashing insuficiente
CSPTF-THRT-NET-004	Explotación de cliente dominante	CSPTF-WEAK-NET-004	Peer management débil
CSPTF-THRT-NET-005	Agotamiento de recursos P2P	CSPTF-WEAK-NET-005	Recuperación de estado no probada

Gate de cierre del dominio

- Aplicabilidad y exclusiones justificadas.
- Controles seleccionados con evidencia proporcional al perfil.
- Tests clasificados pass, fail, inconclusive o formally not-tested.
- Findings con owner, plazo, disclosure handling y retest.
- Dependencias críticas y riesgo residual visibles para el decision maker.

CSPTF-DOM-12 - L2: Layer 2, rollups, secuenciadores y disponibilidad de datos

English: Layer 2, Rollups, Sequencers and Data Availability

Evaluar pruebas, secuenciación, publicación de datos, puentes canónicos, ventanas de desafío, escape hatches y dependencias L1/L2.

Activos principales: sequencers; provers; verifiers; data availability; canonical bridge; fraud proofs; validity proofs; batch inbox.

Alineación de tácticas AADAPT: Execution, Privilege Escalation, Defense Evasion, Impact, Fraud.

NIST CSF 2.0: ID, PR, DE, RC.

OWASP y fuentes relacionadas: OWASP scope is partial; CSPTF extension.

Controles

ID	AP	Control	Requisito normativo	Evidencia esperada
CSPTF-CTRL-L2-001	AP1	Modelo de seguridad L1/L2	La organización DEBE definir, aprobar, implementar, monitorear y revisar modelo de seguridad L1/L2, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con modelo de seguridad L1/L2.
CSPTF-CTRL-L2-002	AP1	Integridad de batches y secuenciación	La organización DEBE definir, aprobar, implementar, monitorear y revisar integridad de batches y secuenciación, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con integridad de batches y secuenciación.
CSPTF-CTRL-L2-003	AP2	Pruebas de fraude o validez	La organización DEBE definir, aprobar, implementar, monitorear y revisar pruebas de fraude o validez, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con pruebas de fraude o validez.
CSPTF-CTRL-L2-004	AP2	Disponibilidad y publicación de datos	La organización DEBE definir, aprobar, implementar, monitorear y revisar disponibilidad y publicación de datos, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con disponibilidad y publicación de datos.
CSPTF-CTRL-L2-005	AP2	Puente canónico y mensajería	La organización DEBE definir, aprobar, implementar, monitorear y revisar puente canónico y mensajería, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con puente canónico y mensajería.
CSPTF-CTRL-L2-006	AP3	Censura, forced inclusion y escape	La organización DEBE definir, aprobar, implementar, monitorear y revisar censura, forced inclusion y escape, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con censura, forced inclusion y escape.
CSPTF-CTRL-L2-007	AP3	Actualizaciones y claves administrativas	La organización DEBE definir, aprobar, implementar, monitorear y revisar actualizaciones y claves administrativas, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con actualizaciones y claves administrativas.
CSPTF-CTRL-L2-008	AP4	Monitoreo de estado y discrepancias	La organización DEBE definir, aprobar,	Política o diseño aprobado; configuración o

ID	AP	Control	Requisito normativo	Evidencia esperada
			implementar, monitorear y revisar monitoreo de estado y discrepancias, manteniendo evidencia trazable y excepciones formalmente aceptadas.	artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con monitoreo de estado y discrepancias.

Casos de prueba autorizados

Regla de seguridad: priorizar review, laboratorio local, fork, testnet y staging. Las acciones activas de producción requieren autorización individual, monitoring, límites, stop authority y reconciliación.

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
CSPTF-TEST-L2-001	AP1	Documentar supuestos L1/L2	Determinar, mediante evidencia verificable y validación no destructiva, si documentar supuestos L1/L2 reduce el riesgo esperado. Revisar diseño y configuración relacionados con documentar supuestos L1/L2, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden documentar supuestos L1/L2. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-L2-002	AP1	Validar construcción y envío de batches	Determinar, mediante evidencia verificable y validación no destructiva, si validar construcción y envío de batches reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar construcción y envío de batches, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar construcción y envío de batches. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-L2-003	AP1	Revisar verificación de pruebas	Determinar, mediante evidencia verificable y validación no destructiva, si revisar verificación de pruebas reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar verificación de pruebas, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar verificación de pruebas. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-L2-004	AP2	Comprobar disponibilidad y reconstrucción de datos	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar disponibilidad y reconstrucción de datos reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar disponibilidad y reconstrucción de datos, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar disponibilidad y reconstrucción de datos. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-L2-005	AP2	Evaluar puente canónico y retiros	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar puente canónico y retiros reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar puente canónico y retiros, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar puente canónico y retiros. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-L2-006	AP2	Validar ventanas de desafío	Determinar, mediante evidencia verificable y	PASS: Existe diseño aprobado, la implementación

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
			validación no destructiva, si validar ventanas de desafío reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar ventanas de desafío, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar ventanas de desafío. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-L2-007	AP2	Revisar forced inclusion y resistencia a censura	Determinar, mediante evidencia verificable y validación no destructiva, si revisar forced inclusion y resistencia a censura reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar forced inclusion y resistencia a censura, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar forced inclusion y resistencia a censura. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-L2-008	AP3	Comprobar roles de secuenciador y prover	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar roles de secuenciador y prover reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar roles de secuenciador y prover, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar roles de secuenciador y prover. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-L2-009	AP3	Evaluar downtime y recuperación	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar downtime y recuperación reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar downtime y recuperación, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar downtime y recuperación. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-L2-010	AP3	Revisar upgrades y timelocks	Determinar, mediante evidencia verificable y validación no destructiva, si revisar upgrades y timelocks reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar upgrades y timelocks, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar upgrades y timelocks. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-L2-011	AP4	Comprobar coherencia de estado L1/L2	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar coherencia de estado L1/L2 reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar coherencia de estado L1/L2, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar coherencia de estado L1/L2. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-L2-012	AP4	Ejecutar simulación de falla de secuenciador	Determinar, mediante evidencia verificable y validación no destructiva, si ejecutar simulación de falla de secuenciador reduce el riesgo esperado. Revisar diseño y configuración relacionados con ejecutar simulación de falla de secuenciador, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden ejecutar simulación de falla de secuenciador. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.

Amenazas y debilidades

Threat ID	Escenario de amenaza	Weakness ID	Patrón de debilidad
CSPTF-THRT-L2-001	Prueba inválida aceptada	CSPTF-WEAK-L2-001	Escape hatch no probado
CSPTF-THRT-L2-002	Censura o indisponibilidad del secuenciador	CSPTF-WEAK-L2-002	DA centralizada
CSPTF-THRT-L2-003	Pérdida de disponibilidad de datos	CSPTF-WEAK-L2-003	Timelock insuficiente
CSPTF-THRT-L2-004	Fraude en puente canónico	CSPTF-WEAK-L2-004	Dependencia de un solo prover
CSPTF-THRT-L2-005	Actualización administrativa maliciosa	CSPTF-WEAK-L2-005	Monitoreo de discrepancias ausente

Gate de cierre del dominio

- Aplicabilidad y exclusiones justificadas.
- Controles seleccionados con evidencia proporcional al perfil.
- Tests clasificados pass, fail, inconclusive o formally not-tested.
- Findings con owner, plazo, disclosure handling y retest.
- Dependencias críticas y riesgo residual visibles para el decision maker.

CSPTF-DOM-13 - CEX: Exchanges centralizados, brokers e infraestructura de mercado

English: Centralized Exchanges, Brokers and Market Infrastructure

Evaluar onboarding, cuentas, trading, depósitos, retiros, matching, custodia, reservas, fraude y procesos operacionales de plataformas centralizadas.

Activos principales: accounts; matching engine; OMS; deposit services; withdrawal services; custody; market data; treasury.

Alineación de tácticas AADAPT: Initial Access, Credential Access, Lateral Movement, Collection, Impact, Fraud.

NIST CSF 2.0: GV, PR, DE, RS, RC.

OWASP y fuentes relacionadas: OWASP scope is partial; CSPTF extension.

Controles

ID	AP	Control	Requisito normativo	Evidencia esperada
CSPTF-CTRL-CEX-001	AP1	Seguridad de cuentas y autenticación	La organización DEBE definir, aprobar, implementar, monitorear y revisar seguridad de cuentas y autenticación, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con seguridad de cuentas y autenticación.
CSPTF-CTRL-CEX-002	AP1	Integridad de órdenes y matching	La organización DEBE definir, aprobar, implementar, monitorear y revisar integridad de órdenes y matching, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con integridad de órdenes y matching.
CSPTF-CTRL-CEX-003	AP2	Depósitos, confirmaciones y atribución	La organización DEBE definir, aprobar, implementar, monitorear y revisar depósitos, confirmaciones y atribución, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con depósitos, confirmaciones y atribución.
CSPTF-CTRL-CEX-004	AP2	Retiros, límites y aprobaciones	La organización DEBE definir, aprobar, implementar, monitorear y revisar retiros, límites y aprobaciones, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con retiros, límites y aprobaciones.
CSPTF-CTRL-CEX-005	AP2	Custodia y tesorería segregadas	La organización DEBE definir, aprobar, implementar, monitorear y revisar custodia y tesorería segregadas, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con custodia y tesorería segregadas.
CSPTF-CTRL-CEX-006	AP3	Market data y prevención de abuso	La organización DEBE definir, aprobar, implementar, monitorear y revisar market data y prevención de abuso, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con market data y prevención de abuso.
CSPTF-CTRL-CEX-007	AP3	Reservas, pasivos y reconciliación	La organización DEBE definir, aprobar, implementar, monitorear y revisar reservas, pasivos y reconciliación, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con reservas, pasivos y reconciliación.
CSPTF-CTRL-CEX-008	AP4	Fraude, monitoreo y continuidad operacional	La organización DEBE definir, aprobar, implementar, monitorear y revisar fraude,	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia

ID	AP	Control	Requisito normativo	Evidencia esperada
			monitoreo y continuidad operacional, manteniendo evidencia trazable y excepciones formalmente aceptadas.	de revisión; prueba de eficacia relacionada con fraude, monitoreo y continuidad operacional.

Casos de prueba autorizados

Regla de seguridad: priorizar review, laboratorio local, fork, testnet y staging. Las acciones activas de producción requieren autorización individual, monitoring, límites, stop authority y reconciliación.

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
CSPTF-TEST-CEX-001	AP1	Evaluar registro, recuperación y MFA	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar registro, recuperación y mfa reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar registro, recuperación y mfa, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar registro, recuperación y mfa. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-CEX-002	AP1	Revisar autorización de cuentas y roles	Determinar, mediante evidencia verificable y validación no destructiva, si revisar autorización de cuentas y roles reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar autorización de cuentas y roles, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar autorización de cuentas y roles. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-CEX-003	AP1	Validar integridad del ciclo de órdenes	Determinar, mediante evidencia verificable y validación no destructiva, si validar integridad del ciclo de órdenes reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar integridad del ciclo de órdenes, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar integridad del ciclo de órdenes. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-CEX-004	AP2	Comprobar idempotencia y concurrencia	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar idempotencia y concurrencia reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar idempotencia y concurrencia, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar idempotencia y concurrencia. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-CEX-005	AP2	Evaluar depósitos y políticas de confirmación	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar depósitos y políticas de confirmación reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar depósitos y políticas de confirmación, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar depósitos y políticas de confirmación. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
CSPTF-TEST-CEX-006	AP2	Revisar retiros, allowlists y cooling-off	Determinar, mediante evidencia verificable y validación no destructiva, si revisar retiros, allowlists y cooling-off reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar retiros, allowlists y cooling-off, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar retiros, allowlists y cooling-off. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-CEX-007	AP2	Validar segregación de custodia y tesorería	Determinar, mediante evidencia verificable y validación no destructiva, si validar segregación de custodia y tesorería reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar segregación de custodia y tesorería, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar segregación de custodia y tesorería. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-CEX-008	AP3	Comprobar reconciliación de libros y cadena	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar reconciliación de libros y cadena reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar reconciliación de libros y cadena, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar reconciliación de libros y cadena. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-CEX-009	AP3	Evaluar manipulación de market data	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar manipulación de market data reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar manipulación de market data, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar manipulación de market data. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-CEX-010	AP3	Revisar controles antifraude y abuso interno	Determinar, mediante evidencia verificable y validación no destructiva, si revisar controles antifraude y abuso interno reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar controles antifraude y abuso interno, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar controles antifraude y abuso interno. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-CEX-011	AP4	Simular interrupción del matching en laboratorio	Determinar, mediante evidencia verificable y validación no destructiva, si simular interrupción del matching en laboratorio reduce el riesgo esperado. Revisar diseño y configuración relacionados con simular interrupción del matching en laboratorio, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden simular interrupción del matching en laboratorio. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-CEX-012	AP4	Validar continuidad, reservas y comunicación	Determinar, mediante evidencia verificable y validación no destructiva, si validar continuidad, reservas y comunicación reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar continuidad, reservas y comunicación, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar continuidad, reservas y comunicación. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
			de solo lectura, datos sintéticos, simulación o reproducción segura.	no tratada.

Amenazas y debilidades

Threat ID	Escenario de amenaza	Weakness ID	Patrón de debilidad
CSPTF-THRT-CEX-001	Toma de cuenta y retiro fraudulento	CSPTF-WEAK-CEX-001	Recuperación de cuenta débil
CSPTF-THRT-CEX-002	Manipulación o pérdida de órdenes	CSPTF-WEAK-CEX-002	Idempotencia insuficiente
CSPTF-THRT-CEX-003	Atribución incorrecta de depósitos	CSPTF-WEAK-CEX-003	Límites de retiro inadecuados
CSPTF-THRT-CEX-004	Abuso interno de tesorería	CSPTF-WEAK-CEX-004	Reconciliación tardía
CSPTF-THRT-CEX-005	Descuadre entre reservas y pasivos	CSPTF-WEAK-CEX-005	Segregación de funciones deficiente

Gate de cierre del dominio

- Aplicabilidad y exclusiones justificadas.
- Controles seleccionados con evidencia proporcional al perfil.
- Tests clasificados pass, fail, inconclusive o formally not-tested.
- Findings con owner, plazo, disclosure handling y retest.
- Dependencias críticas y riesgo residual visibles para el decision maker.

CSPTF-DOM-14 - API: APIs, RPC, WebSocket y plataformas para desarrolladores

English: APIs, RPC, WebSocket and Developer Platforms

Evaluar autenticación, autorización, exposición, rate limiting, seguridad de métodos, datos y disponibilidad en interfaces programáticas.

Activos principales: REST APIs; GraphQL; JSON-RPC; WebSocket; API keys; developer portals; webhooks; indexers.

Alineación de tácticas AADAPT: Reconnaissance, Initial Access, Execution, Credential Access, Collection, Impact.

NIST CSF 2.0: PR, DE.

OWASP y fuentes relacionadas: OWASP API Security Top 10; SCSTG RPC interactions.

Controles

ID	AP	Control	Requisito normativo	Evidencia esperada
CSPTF-CTRL-API-001	AP1	Inventario y clasificación de interfaces	La organización DEBE definir, aprobar, implementar, monitorear y revisar inventario y clasificación de interfaces, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con inventario y clasificación de interfaces.
CSPTF-CTRL-API-002	AP1	Autenticación y gestión de credenciales	La organización DEBE definir, aprobar, implementar, monitorear y revisar autenticación y gestión de credenciales, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con autenticación y gestión de credenciales.
CSPTF-CTRL-API-003	AP2	Autorización por objeto y función	La organización DEBE definir, aprobar, implementar, monitorear y revisar autorización por objeto y función, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con autorización por objeto y función.
CSPTF-CTRL-API-004	AP2	Métodos RPC y superficies administrativas	La organización DEBE definir, aprobar, implementar, monitorear y revisar métodos rpc y superficies administrativas, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con métodos rpc y superficies administrativas.
CSPTF-CTRL-API-005	AP2	Rate limiting, cuotas y antiabuso	La organización DEBE definir, aprobar, implementar, monitorear y revisar rate limiting, cuotas y antiabuso, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con rate limiting, cuotas y antiabuso.
CSPTF-CTRL-API-006	AP3	Validación de entradas y salidas	La organización DEBE definir, aprobar, implementar, monitorear y revisar validación de entradas y salidas, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con validación de entradas y salidas.
CSPTF-CTRL-API-007	AP3	Webhooks, WebSocket y eventos	La organización DEBE definir, aprobar, implementar, monitorear y revisar webhooks, websocket y eventos, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con webhooks, websocket y eventos.
CSPTF-CTRL-API-008	AP4	Observabilidad, versionado y retiro seguro	La organización DEBE definir, aprobar, implementar, monitorear y revisar	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia

ID	AP	Control	Requisito normativo	Evidencia esperada
			observabilidad, versionado y retiro seguro, manteniendo evidencia trazable y excepciones formalmente aceptadas.	de revisión; prueba de eficacia relacionada con observabilidad, versionado y retiro seguro.

Casos de prueba autorizados

Regla de seguridad: priorizar review, laboratorio local, fork, testnet y staging. Las acciones activas de producción requieren autorización individual, monitoring, límites, stop authority y reconciliación.

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
CSPTF-TEST-API-001	AP1	Inventariar endpoints, métodos y versiones	Determinar, mediante evidencia verificable y validación no destructiva, si inventariar endpoints, métodos y versiones reduce el riesgo esperado. Revisar diseño y configuración relacionados con inventariar endpoints, métodos y versiones, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden inventariar endpoints, métodos y versiones. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-API-002	AP1	Evaluar autenticación y ciclo de API keys	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar autenticación y ciclo de api keys reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar autenticación y ciclo de api keys, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar autenticación y ciclo de api keys. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-API-003	AP1	Comprobar autorización por objeto	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar autorización por objeto reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar autorización por objeto, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar autorización por objeto. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-API-004	AP2	Revisar métodos RPC sensibles	Determinar, mediante evidencia verificable y validación no destructiva, si revisar métodos rpc sensibles reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar métodos rpc sensibles, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar métodos rpc sensibles. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-API-005	AP2	Validar rate limiting y cuotas	Determinar, mediante evidencia verificable y validación no destructiva, si validar rate limiting y cuotas reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar rate limiting y cuotas, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar rate limiting y cuotas. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-API-006	AP2	Evaluar validación de parámetros	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar validación de	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
			parámetros reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar validación de parámetros, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	eficacia y no se identifican rutas razonables que invaliden evaluar validación de parámetros. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-API-007	AP2	Comprobar filtrado de datos sensibles	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar filtrado de datos sensibles reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar filtrado de datos sensibles, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar filtrado de datos sensibles. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-API-008	AP3	Revisar WebSocket, suscripciones y sesiones	Determinar, mediante evidencia verificable y validación no destructiva, si revisar websocket, suscripciones y sesiones reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar websocket, suscripciones y sesiones, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar websocket, suscripciones y sesiones. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-API-009	AP3	Validar autenticidad de webhooks	Determinar, mediante evidencia verificable y validación no destructiva, si validar autenticidad de webhooks reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar autenticidad de webhooks, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar autenticidad de webhooks. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-API-010	AP3	Evaluar errores, logs y exposición de stack	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar errores, logs y exposición de stack reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar errores, logs y exposición de stack, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar errores, logs y exposición de stack. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-API-011	AP4	Comprobar versionado y compatibilidad	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar versionado y compatibilidad reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar versionado y compatibilidad, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar versionado y compatibilidad. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-API-012	AP4	Ejecutar pruebas de resiliencia no destructivas	Determinar, mediante evidencia verificable y validación no destructiva, si ejecutar pruebas de resiliencia no destructivas reduce el riesgo esperado. Revisar diseño y configuración relacionados con ejecutar pruebas de resiliencia no destructivas, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden ejecutar pruebas de resiliencia no destructivas. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.

Amenazas y debilidades

Threat ID	Escenario de amenaza	Weakness ID	Patrón de debilidad
CSPTF-THRT-API-001	Abuso de método RPC administrativo	CSPTF-WEAK-API-001	API keys de larga duración
CSPTF-THRT-API-002	Acceso no autorizado a objetos	CSPTF-WEAK-API-002	Autorización a nivel objeto ausente
CSPTF-THRT-API-003	Exfiltración de datos por API	CSPTF-WEAK-API-003	RPC administrativo expuesto
CSPTF-THRT-API-004	Agotamiento de cuota o recursos	CSPTF-WEAK-API-004	Rate limits inconsistentes
CSPTF-THRT-API-005	Falsificación de webhook o evento	CSPTF-WEAK-API-005	Errores excesivamente informativos

Gate de cierre del dominio

- Aplicabilidad y exclusiones justificadas.
- Controles seleccionados con evidencia proporcional al perfil.
- Tests clasificados pass, fail, inconclusive o formally not-tested.
- Findings con owner, plazo, disclosure handling y retest.
- Dependencias críticas y riesgo residual visibles para el decision maker.

CSPTF-DOM-15 - INF: Cloud, contenedores, CI/CD e infraestructura

English: Cloud, Containers, CI/CD and Infrastructure

Evaluar la infraestructura que construye, despliega y opera servicios de activos digitales, incluyendo secretos, IaC, imágenes y pipelines.

Activos principales: cloud accounts; Kubernetes; containers; CI/CD; IaC; artifact registries; secrets managers; observability stack.

Alineación de tácticas AADAPT: Initial Access, Execution, Privilege Escalation, Credential Access, Lateral Movement, Impact.

NIST CSF 2.0: PR, DE, RC.

OWASP y fuentes relacionadas: OWASP DevSecOps and supply-chain practices.

Controles

ID	AP	Control	Requisito normativo	Evidencia esperada
CSPTF-CTRL-INF-001	AP1	Arquitectura cloud y segmentación	La organización DEBE definir, aprobar, implementar, monitorear y revisar arquitectura cloud y segmentación, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con arquitectura cloud y segmentación.
CSPTF-CTRL-INF-002	AP1	IAM de infraestructura y privilegios	La organización DEBE definir, aprobar, implementar, monitorear y revisar iam de infraestructura y privilegios, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con iam de infraestructura y privilegios.
CSPTF-CTRL-INF-003	AP2	Gestión de secretos y KMS	La organización DEBE definir, aprobar, implementar, monitorear y revisar gestión de secretos y kms, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con gestión de secretos y kms.
CSPTF-CTRL-INF-004	AP2	Endurecimiento de contenedores y orquestación	La organización DEBE definir, aprobar, implementar, monitorear y revisar endurecimiento de contenedores y orquestación, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con endurecimiento de contenedores y orquestación.
CSPTF-CTRL-INF-005	AP2	Integridad de CI/CD y releases	La organización DEBE definir, aprobar, implementar, monitorear y revisar integridad de ci/cd y releases, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con integridad de ci/cd y releases.
CSPTF-CTRL-INF-006	AP3	IaC, configuración y drift	La organización DEBE definir, aprobar, implementar, monitorear y revisar iac, configuración y drift, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con iac, configuración y drift.
CSPTF-CTRL-INF-007	AP3	Red, exposición y protección perimetral	La organización DEBE definir, aprobar, implementar, monitorear y revisar red, exposición y protección perimetral, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con red, exposición y protección perimetral.
CSPTF-CTRL-INF-008	AP4	Respaldo, continuidad y recuperación	La organización DEBE definir, aprobar, implementar, monitorear y revisar respaldo,	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia

ID	AP	Control	Requisito normativo	Evidencia esperada
			continuidad y recuperación, manteniendo evidencia trazable y excepciones formalmente aceptadas.	de revisión; prueba de eficacia relacionada con respaldo, continuidad y recuperación.

Casos de prueba autorizados

Regla de seguridad: priorizar review, laboratorio local, fork, testnet y staging. Las acciones activas de producción requieren autorización individual, monitoring, límites, stop authority y reconciliación.

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
CSPTF-TEST-INF-001	AP1	Revisar cuentas, proyectos y segmentación	Determinar, mediante evidencia verificable y validación no destructiva, si revisar cuentas, proyectos y segmentación reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar cuentas, proyectos y segmentación, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar cuentas, proyectos y segmentación. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-INF-002	AP1	Evaluar IAM y privilegios cloud	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar iam y privilegios cloud reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar iam y privilegios cloud, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar iam y privilegios cloud. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-INF-003	AP1	Comprobar secretos, KMS y rotación	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar secretos, kms y rotación reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar secretos, kms y rotación, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar secretos, kms y rotación. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-INF-004	AP2	Revisar imágenes y configuración de contenedores	Determinar, mediante evidencia verificable y validación no destructiva, si revisar imágenes y configuración de contenedores reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar imágenes y configuración de contenedores, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar imágenes y configuración de contenedores. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-INF-005	AP2	Evaluar controles de Kubernetes	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar controles de kubernetes reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar controles de kubernetes, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar controles de kubernetes. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
CSPTF-TEST-INF-006	AP2	Comprobar integridad del pipeline y aprobaciones	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar integridad del pipeline y aprobaciones reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar integridad del pipeline y aprobaciones, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar integridad del pipeline y aprobaciones. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-INF-007	AP2	Validar firma y procedencia de artefactos	Determinar, mediante evidencia verificable y validación no destructiva, si validar firma y procedencia de artefactos reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar firma y procedencia de artefactos, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar firma y procedencia de artefactos. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-INF-008	AP3	Revisar IaC y drift de configuración	Determinar, mediante evidencia verificable y validación no destructiva, si revisar iac y drift de configuración reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar iac y drift de configuración, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar iac y drift de configuración. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-INF-009	AP3	Evaluar exposición de red y servicios	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar exposición de red y servicios reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar exposición de red y servicios, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar exposición de red y servicios. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-INF-010	AP3	Comprobar logs, métricas y alertas	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar logs, métricas y alertas reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar logs, métricas y alertas, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar logs, métricas y alertas. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-INF-011	AP4	Validar backups y restauración	Determinar, mediante evidencia verificable y validación no destructiva, si validar backups y restauración reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar backups y restauración, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar backups y restauración. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-INF-012	AP4	Simular pérdida controlada de un componente	Determinar, mediante evidencia verificable y validación no destructiva, si simular pérdida controlada de un componente reduce el riesgo esperado. Revisar diseño y configuración relacionados con simular pérdida controlada de un componente, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden simular pérdida controlada de un componente. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
			de solo lectura, datos sintéticos, simulación o reproducción segura.	no tratada.

Amenazas y debilidades

Threat ID	Escenario de amenaza	Weakness ID	Patrón de debilidad
CSPTF-THRT-INF-001	Compromiso de pipeline de despliegue	CSPTF-WEAK-INF-001	Roles cloud excesivos
CSPTF-THRT-INF-002	Exposición de secreto de producción	CSPTF-WEAK-INF-002	Secretos en variables o repositorios
CSPTF-THRT-INF-003	Escape o abuso de contenedor	CSPTF-WEAK-INF-003	Imágenes no firmadas
CSPTF-THRT-INF-004	Toma de cuenta cloud privilegiada	CSPTF-WEAK-INF-004	Kubernetes mal endurecido
CSPTF-THRT-INF-005	Pérdida de infraestructura sin recuperación	CSPTF-WEAK-INF-005	Backups no restaurados en pruebas

Gate de cierre del dominio

- Aplicabilidad y exclusiones justificadas.
- Controles seleccionados con evidencia proporcional al perfil.
- Tests clasificados pass, fail, inconclusive o formally not-tested.
- Findings con owner, plazo, disclosure handling y retest.
- Dependencias críticas y riesgo residual visibles para el decision maker.

CSPTF-DOM-16 - IAM: Identidad, acceso privilegiado y riesgo interno

English: Identity, Privileged Access and Insider Risk

Evaluar identidades humanas y de máquina, acceso privilegiado, segregación, revisiones, monitoreo y controles frente a fraude o abuso interno.

Activos principales: workforce identities; service accounts; PAM; break-glass accounts; admin consoles; signer roles; vendors; joiner-mover-leaver.

Alineación de tácticas AADAPT: Initial Access, Privilege Escalation, Credential Access, Lateral Movement, Collection, Fraud.

NIST CSF 2.0: GV, PR, DE.

OWASP y fuentes relacionadas: OWASP ASVS authentication and access control.

Controles

ID	AP	Control	Requisito normativo	Evidencia esperada
CSPTF-CTRL-IAM-001	AP1	Gobierno del ciclo de identidad	La organización DEBE definir, aprobar, implementar, monitorear y revisar gobierno del ciclo de identidad, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con gobierno del ciclo de identidad.
CSPTF-CTRL-IAM-002	AP1	MFA resistente y autenticación fuerte	La organización DEBE definir, aprobar, implementar, monitorear y revisar mfa resistente y autenticación fuerte, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con mfa resistente y autenticación fuerte.
CSPTF-CTRL-IAM-003	AP2	Mínimo privilegio y acceso just-in-time	La organización DEBE definir, aprobar, implementar, monitorear y revisar mínimo privilegio y acceso just-in-time, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con mínimo privilegio y acceso just-in-time.
CSPTF-CTRL-IAM-004	AP2	Segregación de funciones críticas	La organización DEBE definir, aprobar, implementar, monitorear y revisar segregación de funciones críticas, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con segregación de funciones críticas.
CSPTF-CTRL-IAM-005	AP2	PAM, sesiones y cuentas break-glass	La organización DEBE definir, aprobar, implementar, monitorear y revisar pam, sesiones y cuentas break-glass, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con pam, sesiones y cuentas break-glass.
CSPTF-CTRL-IAM-006	AP3	Identidades de máquina y workloads	La organización DEBE definir, aprobar, implementar, monitorear y revisar identidades de máquina y workloads, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con identidades de máquina y workloads.
CSPTF-CTRL-IAM-007	AP3	Monitoreo de comportamiento privilegiado	La organización DEBE definir, aprobar, implementar, monitorear y revisar monitoreo de comportamiento privilegiado, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con monitoreo de comportamiento privilegiado.

ID	AP	Control	Requisito normativo	Evidencia esperada
CSPTF-CTRL-IAM-008	AP4	Gestión de terceros y salida segura	La organización DEBE definir, aprobar, implementar, monitorear y revisar gestión de terceros y salida segura, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con gestión de terceros y salida segura.

Casos de prueba autorizados

Regla de seguridad: priorizar review, laboratorio local, fork, testnet y staging. Las acciones activas de producción requieren autorización individual, monitoring, límites, stop authority y reconciliación.

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
CSPTF-TEST-IAM-001	AP1	Revisar altas, cambios y bajas	Determinar, mediante evidencia verificable y validación no destructiva, si revisar altas, cambios y bajas reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar altas, cambios y bajas, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar altas, cambios y bajas. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-IAM-002	AP1	Evaluar MFA y recuperación de acceso	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar mfa y recuperación de acceso reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar mfa y recuperación de acceso, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar mfa y recuperación de acceso. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-IAM-003	AP1	Comprobar privilegios efectivos	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar privilegios efectivos reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar privilegios efectivos, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar privilegios efectivos. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-IAM-004	AP2	Validar segregación de funciones	Determinar, mediante evidencia verificable y validación no destructiva, si validar segregación de funciones reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar segregación de funciones, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar segregación de funciones. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-IAM-005	AP2	Revisar PAM y grabación de sesiones	Determinar, mediante evidencia verificable y validación no destructiva, si revisar pam y grabación de sesiones reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar pam y grabación de sesiones, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar pam y grabación de sesiones. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
CSPTF-TEST-IAM-006	AP2	Comprobar cuentas break-glass	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar cuentas break-glass reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar cuentas break-glass, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar cuentas break-glass. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-IAM-007	AP2	Evaluar identidades de máquina	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar identidades de máquina reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar identidades de máquina, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar identidades de máquina. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-IAM-008	AP3	Revisar accesos de terceros	Determinar, mediante evidencia verificable y validación no destructiva, si revisar accesos de terceros reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar accesos de terceros, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar accesos de terceros. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-IAM-009	AP3	Validar recertificación periódica	Determinar, mediante evidencia verificable y validación no destructiva, si validar recertificación periódica reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar recertificación periódica, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar recertificación periódica. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-IAM-010	AP3	Comprobar monitoreo de acciones críticas	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar monitoreo de acciones críticas reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar monitoreo de acciones críticas, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar monitoreo de acciones críticas. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-IAM-011	AP4	Ejecutar tabletop de abuso interno	Determinar, mediante evidencia verificable y validación no destructiva, si ejecutar tabletop de abuso interno reduce el riesgo esperado. Revisar diseño y configuración relacionados con ejecutar tabletop de abuso interno, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden ejecutar tabletop de abuso interno. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-IAM-012	AP4	Validar revocación y preservación de evidencia	Determinar, mediante evidencia verificable y validación no destructiva, si validar revocación y preservación de evidencia reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar revocación y preservación de evidencia, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar revocación y preservación de evidencia. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.

Amenazas y debilidades

Threat ID	Escenario de amenaza	Weakness ID	Patrón de debilidad
CSPTF-THRT-IAM-001	Abuso de administrador o firmante	CSPTF-WEAK-IAM-001	Privilegios permanentes
CSPTF-THRT-IAM-002	Toma de cuenta privilegiada	CSPTF-WEAK-IAM-002	MFA recuperable por canal débil
CSPTF-THRT-IAM-003	Persistencia de excolaborador o tercero	CSPTF-WEAK-IAM-003	Segregación de funciones incompleta
CSPTF-THRT-IAM-004	Colusión entre funciones críticas	CSPTF-WEAK-IAM-004	Cuentas compartidas
CSPTF-THRT-IAM-005	Uso no autorizado de identidad de máquina	CSPTF-WEAK-IAM-005	Recertificación insuficiente

Gate de cierre del dominio

- Aplicabilidad y exclusiones justificadas.
- Controles seleccionados con evidencia proporcional al perfil.
- Tests clasificados pass, fail, inconclusive o formally not-tested.
- Findings con owner, plazo, disclosure handling y retest.
- Dependencias críticas y riesgo residual visibles para el decision maker.

CSPTF-DOM-17 - SUP: Cadena de suministro, dependencias e integridad de construcción

English: Supply Chain, Dependencies and Build Integrity

Evaluar componentes, repositorios, compiladores, paquetes, artefactos, proveedores y procedencia del software y firmware.

Activos principales: source repositories; dependencies; package registries; compilers; build runners; artifacts; firmware; vendors.

Alineación de tácticas AADAPT: Resource Development, Initial Access, Execution, Defense Evasion, Impact.

NIST CSF 2.0: GV, ID, PR.

OWASP y fuentes relacionadas: OWASP Software Component Verification Standard themes.

Controles

ID	AP	Control	Requisito normativo	Evidencia esperada
CSPTF-CTRL-SUP-001	AP1	Inventario SBOM y dependencias	La organización DEBE definir, aprobar, implementar, monitorear y revisar inventario sbom y dependencias, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con inventario sbom y dependencias.
CSPTF-CTRL-SUP-002	AP1	Gobierno de repositorios y ramas	La organización DEBE definir, aprobar, implementar, monitorear y revisar gobierno de repositorios y ramas, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con gobierno de repositorios y ramas.
CSPTF-CTRL-SUP-003	AP2	Verificación de paquetes y procedencia	La organización DEBE definir, aprobar, implementar, monitorear y revisar verificación de paquetes y procedencia, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con verificación de paquetes y procedencia.
CSPTF-CTRL-SUP-004	AP2	Entornos de construcción aislados	La organización DEBE definir, aprobar, implementar, monitorear y revisar entornos de construcción aislados, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con entornos de construcción aislados.
CSPTF-CTRL-SUP-005	AP2	Firmas, reproducibilidad y releases	La organización DEBE definir, aprobar, implementar, monitorear y revisar firmas, reproducibilidad y releases, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con firmas, reproducibilidad y releases.
CSPTF-CTRL-SUP-006	AP3	Gestión de vulnerabilidades de terceros	La organización DEBE definir, aprobar, implementar, monitorear y revisar gestión de vulnerabilidades de terceros, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con gestión de vulnerabilidades de terceros.
CSPTF-CTRL-SUP-007	AP3	Firmware y hardware de confianza	La organización DEBE definir, aprobar, implementar, monitorear y revisar firmware y hardware de confianza, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con firmware y hardware de confianza.
CSPTF-CTRL-SUP-008	AP4	Respuesta a compromiso de supply chain	La organización DEBE definir, aprobar, implementar, monitorear y revisar respuesta a	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia

ID	AP	Control	Requisito normativo	Evidencia esperada
			compromiso de supply chain, manteniendo evidencia trazable y excepciones formalmente aceptadas.	de revisión; prueba de eficacia relacionada con respuesta a compromiso de supply chain.

Casos de prueba autorizados

Regla de seguridad: priorizar review, laboratorio local, fork, testnet y staging. Las acciones activas de producción requieren autorización individual, monitoring, límites, stop authority y reconciliación.

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
CSPTF-TEST-SUP-001	AP1	Generar y revisar SBOM	Determinar, mediante evidencia verificable y validación no destructiva, si generar y revisar sbom reduce el riesgo esperado. Revisar diseño y configuración relacionados con generar y revisar sbom, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden generar y revisar sbom. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-SUP-002	AP1	Validar protección de ramas y revisiones	Determinar, mediante evidencia verificable y validación no destructiva, si validar protección de ramas y revisiones reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar protección de ramas y revisiones, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar protección de ramas y revisiones. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-SUP-003	AP1	Evaluar dependencias directas y transitivas	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar dependencias directas y transitivas reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar dependencias directas y transitivas, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar dependencias directas y transitivas. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-SUP-004	AP2	Comprobar pinning, hashes y registries	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar pinning, hashes y registries reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar pinning, hashes y registries, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar pinning, hashes y registries. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-SUP-005	AP2	Revisar runners y entornos de build	Determinar, mediante evidencia verificable y validación no destructiva, si revisar runners y entornos de build reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar runners y entornos de build, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar runners y entornos de build. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-SUP-006	AP2	Validar firma y procedencia de artefactos	Determinar, mediante evidencia verificable y validación no destructiva, si validar firma y	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
			procedencia de artefactos reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar firma y procedencia de artefactos, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	eficacia y no se identifican rutas razonables que invaliden validar firma y procedencia de artefactos. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-SUP-007	AP2	Comprobar builds reproducibles donde aplique	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar builds reproducibles donde aplique reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar builds reproducibles donde aplique, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar builds reproducibles donde aplique. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-SUP-008	AP3	Evaluar compiladores y toolchains	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar compiladores y toolchains reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar compiladores y toolchains, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar compiladores y toolchains. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-SUP-009	AP3	Revisar firmware y actualizaciones	Determinar, mediante evidencia verificable y validación no destructiva, si revisar firmware y actualizaciones reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar firmware y actualizaciones, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar firmware y actualizaciones. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-SUP-010	AP3	Validar riesgo y acceso de proveedores	Determinar, mediante evidencia verificable y validación no destructiva, si validar riesgo y acceso de proveedores reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar riesgo y acceso de proveedores, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar riesgo y acceso de proveedores. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-SUP-011	AP4	Simular revocación de componente comprometido	Determinar, mediante evidencia verificable y validación no destructiva, si simular revocación de componente comprometido reduce el riesgo esperado. Revisar diseño y configuración relacionados con simular revocación de componente comprometido, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden simular revocación de componente comprometido. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-SUP-012	AP4	Comprobar detección de cambios no autorizados	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar detección de cambios no autorizados reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar detección de cambios no autorizados, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar detección de cambios no autorizados. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
			reproducción segura.	

Amenazas y debilidades

Threat ID	Escenario de amenaza	Weakness ID	Patrón de debilidad
CSPTF-THRT-SUP-001	Paquete o dependencia maliciosa	CSPTF-WEAK-SUP-001	Dependencias sin pinning
CSPTF-THRT-SUP-002	Compromiso de repositorio o maintainer	CSPTF-WEAK-SUP-002	Artefactos no firmados
CSPTF-THRT-SUP-003	Manipulación del pipeline de build	CSPTF-WEAK-SUP-003	Runners compartidos y privilegiados
CSPTF-THRT-SUP-004	Firmware o dispositivo adulterado	CSPTF-WEAK-SUP-004	SBOM ausente
CSPTF-THRT-SUP-005	Actualización comprometida distribuida	CSPTF-WEAK-SUP-005	Proveedores sin evaluación continua

Gate de cierre del dominio

- Aplicabilidad y exclusiones justificadas.
- Controles seleccionados con evidencia proporcional al perfil.
- Tests clasificados pass, fail, inconclusive o formally not-tested.
- Findings con owner, plazo, disclosure handling y retest.
- Dependencias críticas y riesgo residual visibles para el decision maker.

CSPTF-DOM-18 - REG: Privacidad, cumplimiento, AML/KYT y protección de datos

English: Privacy, Compliance, AML/KYT and Data Protection

Evaluar obligaciones aplicables, minimización, trazabilidad, privacidad, controles AML/KYT y tratamiento seguro de datos personales y financieros.

Activos principales: PII; KYC records; transaction monitoring; sanctions screening; travel rule data; audit records; privacy notices; retention systems.

Alineación de tácticas AADAPT: Collection, Defense Evasion, Impact, Fraud.

NIST CSF 2.0: GV, ID, PR.

OWASP y fuentes relacionadas: OWASP privacy and data protection themes.

Controles

ID	AP	Control	Requisito normativo	Evidencia esperada
CSPTF-CTRL-REG-001	AP1	Inventario de obligaciones y jurisdicciones	La organización DEBE definir, aprobar, implementar, monitorear y revisar inventario de obligaciones y jurisdicciones, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con inventario de obligaciones y jurisdicciones.
CSPTF-CTRL-REG-002	AP1	Minimización y propósito de datos	La organización DEBE definir, aprobar, implementar, monitorear y revisar minimización y propósito de datos, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con minimización y propósito de datos.
CSPTF-CTRL-REG-003	AP2	Seguridad de KYC y datos sensibles	La organización DEBE definir, aprobar, implementar, monitorear y revisar seguridad de kyc y datos sensibles, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con seguridad de kyc y datos sensibles.
CSPTF-CTRL-REG-004	AP2	AML, KYT y screening basado en riesgo	La organización DEBE definir, aprobar, implementar, monitorear y revisar aml, kyt y screening basado en riesgo, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con aml, kyt y screening basado en riesgo.
CSPTF-CTRL-REG-005	AP2	Travel Rule y transferencia segura	La organización DEBE definir, aprobar, implementar, monitorear y revisar travel rule y transferencia segura, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con travel rule y transferencia segura.
CSPTF-CTRL-REG-006	AP3	Retención, borrado y derechos	La organización DEBE definir, aprobar, implementar, monitorear y revisar retención, borrado y derechos, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con retención, borrado y derechos.
CSPTF-CTRL-REG-007	AP3	Trazabilidad y evidencia regulatoria	La organización DEBE definir, aprobar, implementar, monitorear y revisar trazabilidad y evidencia regulatoria, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con trazabilidad y evidencia regulatoria.
CSPTF-CTRL-REG-008	AP4	Privacidad por diseño en datos on-chain	La organización DEBE definir, aprobar, implementar, monitorear y revisar privacidad por diseño en datos on-chain, manteniendo	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con

ID	AP	Control	Requisito normativo	Evidencia esperada
			evidencia trazable y excepciones formalmente aceptadas.	privacidad por diseño en datos on-chain.

Casos de prueba autorizados

Regla de seguridad: priorizar review, laboratorio local, fork, testnet y staging. Las acciones activas de producción requieren autorización individual, monitoring, límites, stop authority y reconciliación.

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
CSPTF-TEST-REG-001	AP1	Identificar obligaciones y alcance regulatorio	Determinar, mediante evidencia verificable y validación no destructiva, si identificar obligaciones y alcance regulatorio reduce el riesgo esperado. Revisar diseño y configuración relacionados con identificar obligaciones y alcance regulatorio, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden identificar obligaciones y alcance regulatorio. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-REG-002	AP1	Revisar inventario y clasificación de datos	Determinar, mediante evidencia verificable y validación no destructiva, si revisar inventario y clasificación de datos reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar inventario y clasificación de datos, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar inventario y clasificación de datos. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-REG-003	AP1	Validar minimización y propósito	Determinar, mediante evidencia verificable y validación no destructiva, si validar minimización y propósito reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar minimización y propósito, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar minimización y propósito. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-REG-004	AP2	Evaluar protección de datos KYC	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar protección de datos kyc reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar protección de datos kyc, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar protección de datos kyc. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-REG-005	AP2	Comprobar controles AML y KYT	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar controles aml y kyt reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar controles aml y kyt, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar controles aml y kyt. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-REG-006	AP2	Revisar screening y manejo de falsos positivos	Determinar, mediante evidencia verificable y validación no destructiva, si revisar screening y manejo de falsos positivos reduce el riesgo	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
			esperado. Revisar diseño y configuración relacionados con revisar screening y manejo de falsos positivos, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	invaliden revisar screening y manejo de falsos positivos. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-REG-007	AP2	Validar Travel Rule y transferencias	Determinar, mediante evidencia verificable y validación no destructiva, si validar travel rule y transferencias reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar travel rule y transferencias, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar travel rule y transferencias. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-REG-008	AP3	Comprobar retención y eliminación	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar retención y eliminación reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar retención y eliminación, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar retención y eliminación. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-REG-009	AP3	Evaluar privacidad y linkability on-chain	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar privacidad y linkability on-chain reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar privacidad y linkability on-chain, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar privacidad y linkability on-chain. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-REG-010	AP3	Revisar accesos y trazabilidad regulatoria	Determinar, mediante evidencia verificable y validación no destructiva, si revisar accesos y trazabilidad regulatoria reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar accesos y trazabilidad regulatoria, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar accesos y trazabilidad regulatoria. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-REG-011	AP4	Validar respuesta a solicitudes de titulares	Determinar, mediante evidencia verificable y validación no destructiva, si validar respuesta a solicitudes de titulares reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar respuesta a solicitudes de titulares, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar respuesta a solicitudes de titulares. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-REG-012	AP4	Ejecutar tabletop de incidente de datos	Determinar, mediante evidencia verificable y validación no destructiva, si ejecutar tabletop de incidente de datos reduce el riesgo esperado. Revisar diseño y configuración relacionados con ejecutar tabletop de incidente de datos, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden ejecutar tabletop de incidente de datos. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.

Amenazas y debilidades

Threat ID	Escenario de amenaza	Weakness ID	Patrón de debilidad
CSPTF-THRT-REG-001	Exposición de datos KYC	CSPTF-WEAK-REG-001	Datos KYC sobreexpuestos
CSPTF-THRT-REG-002	Evasión de monitoreo transaccional	CSPTF-WEAK-REG-002	Reglas AML estáticas
CSPTF-THRT-REG-003	Transferencia regulada sin datos requeridos	CSPTF-WEAK-REG-003	Minimización insuficiente
CSPTF-THRT-REG-004	Reidentificación o linkability indebida	CSPTF-WEAK-REG-004	Cifrado o tokenización inadecuados
CSPTF-THRT-REG-005	Retención o uso incompatible de datos	CSPTF-WEAK-REG-005	Obligaciones no mapeadas por jurisdicción

Gate de cierre del dominio

- Aplicabilidad y exclusiones justificadas.
- Controles seleccionados con evidencia proporcional al perfil.
- Tests clasificados pass, fail, inconclusive o formally not-tested.
- Findings con owner, plazo, disclosure handling y retest.
- Dependencias críticas y riesgo residual visibles para el decision maker.

CSPTF-DOM-19 - MON: Monitoreo, detección, analítica on-chain y fraude

English: Monitoring, Detection, On-chain Analytics and Fraud

Evaluar cobertura, calidad, correlación y respuesta de telemetría off-chain/on-chain frente a fraude, compromiso y anomalías económicas.

Activos principales: SIEM; on-chain analytics; fraud rules; wallet monitoring; node logs; contract events; alerting; case management.

Alineación de tácticas AADAPT: Defense Evasion, Collection, Impact, Fraud.

NIST CSF 2.0: DE, RS.

OWASP y fuentes relacionadas: SCSTG logging and event verification.

Controles

ID	AP	Control	Requisito normativo	Evidencia esperada
CSPTF-CTRL-MON-001	AP1	Estrategia y cobertura de telemetría	La organización DEBE definir, aprobar, implementar, monitorear y revisar estrategia y cobertura de telemetría, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con estrategia y cobertura de telemetría.
CSPTF-CTRL-MON-002	AP1	Calidad, tiempo y sincronización de logs	La organización DEBE definir, aprobar, implementar, monitorear y revisar calidad, tiempo y sincronización de logs, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con calidad, tiempo y sincronización de logs.
CSPTF-CTRL-MON-003	AP2	Detecciones on-chain y off-chain	La organización DEBE definir, aprobar, implementar, monitorear y revisar detecciones on-chain y off-chain, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con detecciones on-chain y off-chain.
CSPTF-CTRL-MON-004	AP2	Monitoreo de wallets y contratos críticos	La organización DEBE definir, aprobar, implementar, monitorear y revisar monitoreo de wallets y contratos críticos, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con monitoreo de wallets y contratos críticos.
CSPTF-CTRL-MON-005	AP2	Detección de fraude y abuso	La organización DEBE definir, aprobar, implementar, monitorear y revisar detección de fraude y abuso, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con detección de fraude y abuso.
CSPTF-CTRL-MON-006	AP3	Correlación, enriquecimiento y atribución	La organización DEBE definir, aprobar, implementar, monitorear y revisar correlación, enriquecimiento y atribución, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con correlación, enriquecimiento y atribución.
CSPTF-CTRL-MON-007	AP3	Gestión de alertas y casos	La organización DEBE definir, aprobar, implementar, monitorear y revisar gestión de alertas y casos, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con gestión de alertas y casos.
CSPTF-CTRL-MON-008	AP4	Validación continua de detecciones	La organización DEBE definir, aprobar, implementar, monitorear y revisar validación	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia

ID	AP	Control	Requisito normativo	Evidencia esperada
			continua de detecciones, manteniendo evidencia trazable y excepciones formalmente aceptadas.	de revisión; prueba de eficacia relacionada con validación continua de detecciones.

Casos de prueba autorizados

Regla de seguridad: priorizar review, laboratorio local, fork, testnet y staging. Las acciones activas de producción requieren autorización individual, monitoring, límites, stop authority y reconciliación.

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
CSPTF-TEST-MON-001	AP1	Mapear telemetría a activos y amenazas	Determinar, mediante evidencia verificable y validación no destructiva, si mapear telemetría a activos y amenazas reduce el riesgo esperado. Revisar diseño y configuración relacionados con mapear telemetría a activos y amenazas, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden mapear telemetría a activos y amenazas. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-MON-002	AP1	Validar fuentes, integridad y retención de logs	Determinar, mediante evidencia verificable y validación no destructiva, si validar fuentes, integridad y retención de logs reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar fuentes, integridad y retención de logs, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar fuentes, integridad y retención de logs. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-MON-003	AP1	Comprobar sincronización temporal	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar sincronización temporal reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar sincronización temporal, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar sincronización temporal. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-MON-004	AP2	Evaluar eventos de contratos y nodos	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar eventos de contratos y nodos reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar eventos de contratos y nodos, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar eventos de contratos y nodos. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-MON-005	AP2	Revisar monitoreo de wallets críticas	Determinar, mediante evidencia verificable y validación no destructiva, si revisar monitoreo de wallets críticas reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar monitoreo de wallets críticas, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar monitoreo de wallets críticas. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-MON-006	AP2	Probar detecciones de cambios administrativos	Determinar, mediante evidencia verificable y	PASS: Existe diseño aprobado, la implementación

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
			validación no destructiva, si probar detecciones de cambios administrativos reduce el riesgo esperado. Revisar diseño y configuración relacionados con probar detecciones de cambios administrativos, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden probar detecciones de cambios administrativos. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-MON-007	AP2	Evaluar reglas de fraude y anomalías	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar reglas de fraude y anomalías reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar reglas de fraude y anomalías, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar reglas de fraude y anomalías. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-MON-008	AP3	Comprobar correlación on-chain/off-chain	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar correlación on-chain/off-chain reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar correlación on-chain/off-chain, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar correlación on-chain/off-chain. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-MON-009	AP3	Validar enriquecimiento y contexto	Determinar, mediante evidencia verificable y validación no destructiva, si validar enriquecimiento y contexto reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar enriquecimiento y contexto, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar enriquecimiento y contexto. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-MON-010	AP3	Revisar SLAs y escalamiento	Determinar, mediante evidencia verificable y validación no destructiva, si revisar slas y escalamiento reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar slas y escalamiento, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar slas y escalamiento. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-MON-011	AP4	Ejecutar emulación segura de señales	Determinar, mediante evidencia verificable y validación no destructiva, si ejecutar emulación segura de señales reduce el riesgo esperado. Revisar diseño y configuración relacionados con ejecutar emulación segura de señales, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden ejecutar emulación segura de señales. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-MON-012	AP4	Medir cobertura, precisión y mejora continua	Determinar, mediante evidencia verificable y validación no destructiva, si medir cobertura, precisión y mejora continua reduce el riesgo esperado. Revisar diseño y configuración relacionados con medir cobertura, precisión y mejora continua, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden medir cobertura, precisión y mejora continua. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.

Amenazas y debilidades

Threat ID	Escenario de amenaza	Weakness ID	Patrón de debilidad
CSPTF-THRT-MON-001	Actividad maliciosa no detectada	CSPTF-WEAK-MON-001	Logs críticos ausentes
CSPTF-THRT-MON-002	Supresión o manipulación de telemetría	CSPTF-WEAK-MON-002	Eventos sin contexto de negocio
CSPTF-THRT-MON-003	Falsos positivos que ocultan señales reales	CSPTF-WEAK-MON-003	Alertas sin owner
CSPTF-THRT-MON-004	Fraude coordinado multicanal	CSPTF-WEAK-MON-004	Cobertura no medida
CSPTF-THRT-MON-005	Respuesta tardía a drenaje o compromiso	CSPTF-WEAK-MON-005	Retención insuficiente para investigación

Gate de cierre del dominio

- Aplicabilidad y exclusiones justificadas.
- Controles seleccionados con evidencia proporcional al perfil.
- Tests clasificados pass, fail, inconclusive o formally not-tested.
- Findings con owner, plazo, disclosure handling y retest.
- Dependencias críticas y riesgo residual visibles para el decision maker.

CSPTF-DOM-20 - IRR: Respuesta a incidentes, recuperación, reservas y resiliencia

English: Incident Response, Recovery, Reserves and Resilience

Evaluar preparación, contención, recuperación, reconciliación, comunicación, evidencia, reservas y continuidad ante incidentes de activos digitales.

Activos principales: incident plans; war room; pause mechanisms; recovery keys; reserve ledgers; communications; forensic data; business continuity.

Alineación de tácticas AADAPT: Defense Evasion, Impact, Fraud.

NIST CSF 2.0: RS, RC.

OWASP y fuentes relacionadas: SCSTG incident-aware testing; CSPTF extension.

Controles

ID	AP	Control	Requisito normativo	Evidencia esperada
CSPTF-CTRL-IRR-001	AP1	Planes específicos por escenario	La organización DEBE definir, aprobar, implementar, monitorear y revisar planes específicos por escenario, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con planes específicos por escenario.
CSPTF-CTRL-IRR-002	AP1	Autoridad, coordinación y comunicaciones	La organización DEBE definir, aprobar, implementar, monitorear y revisar autoridad, coordinación y comunicaciones, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con autoridad, coordinación y comunicaciones.
CSPTF-CTRL-IRR-003	AP2	Contención on-chain y off-chain	La organización DEBE definir, aprobar, implementar, monitorear y revisar contención on-chain y off-chain, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con contención on-chain y off-chain.
CSPTF-CTRL-IRR-004	AP2	Preservación de evidencia y forense	La organización DEBE definir, aprobar, implementar, monitorear y revisar preservación de evidencia y forense, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con preservación de evidencia y forense.
CSPTF-CTRL-IRR-005	AP2	Recuperación de claves y servicios	La organización DEBE definir, aprobar, implementar, monitorear y revisar recuperación de claves y servicios, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con recuperación de claves y servicios.
CSPTF-CTRL-IRR-006	AP3	Reconciliación de activos y reservas	La organización DEBE definir, aprobar, implementar, monitorear y revisar reconciliación de activos y reservas, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con reconciliación de activos y reservas.
CSPTF-CTRL-IRR-007	AP3	Continuidad, liquidez y obligaciones	La organización DEBE definir, aprobar, implementar, monitorear y revisar continuidad, liquidez y obligaciones, manteniendo evidencia trazable y excepciones formalmente aceptadas.	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia de revisión; prueba de eficacia relacionada con continuidad, liquidez y obligaciones.
CSPTF-CTRL-IRR-008	AP4	Lecciones aprendidas y validación periódica	La organización DEBE definir, aprobar, implementar, monitorear y revisar lecciones	Política o diseño aprobado; configuración o artefacto técnico; registro operativo; evidencia

ID	AP	Control	Requisito normativo	Evidencia esperada
			aprendidas y validación periódica, manteniendo evidencia trazable y excepciones formalmente aceptadas.	de revisión; prueba de eficacia relacionada con lecciones aprendidas y validación periódica.

Casos de prueba autorizados

Regla de seguridad: priorizar review, laboratorio local, fork, testnet y staging. Las acciones activas de producción requieren autorización individual, monitoring, límites, stop authority y reconciliación.

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
CSPTF-TEST-IRR-001	AP1	Revisar playbooks por escenario	Determinar, mediante evidencia verificable y validación no destructiva, si revisar playbooks por escenario reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar playbooks por escenario, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar playbooks por escenario. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-IRR-002	AP1	Validar contactos, roles y autoridad	Determinar, mediante evidencia verificable y validación no destructiva, si validar contactos, roles y autoridad reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar contactos, roles y autoridad, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar contactos, roles y autoridad. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-IRR-003	AP1	Comprobar mecanismos de pausa y contención	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar mecanismos de pausa y contención reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar mecanismos de pausa y contención, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar mecanismos de pausa y contención. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-IRR-004	AP2	Evaluar preservación de evidencia	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar preservación de evidencia reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar preservación de evidencia, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar preservación de evidencia. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-IRR-005	AP2	Simular compromiso de clave	Determinar, mediante evidencia verificable y validación no destructiva, si simular compromiso de clave reduce el riesgo esperado. Revisar diseño y configuración relacionados con simular compromiso de clave, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden simular compromiso de clave. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-IRR-006	AP2	Simular exploit de contrato o bridge	Determinar, mediante evidencia verificable y	PASS: Existe diseño aprobado, la implementación

ID	AP	Prueba	Objetivo y método seguro	Criterios pass / fail
			validación no destructiva, si simular exploit de contrato o bridge reduce el riesgo esperado. Revisar diseño y configuración relacionados con simular exploit de contrato o bridge, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden simular exploit de contrato o bridge. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-IRR-007	AP2	Validar restauración de servicios	Determinar, mediante evidencia verificable y validación no destructiva, si validar restauración de servicios reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar restauración de servicios, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar restauración de servicios. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-IRR-008	AP3	Comprobar reconciliación de balances	Determinar, mediante evidencia verificable y validación no destructiva, si comprobar reconciliación de balances reduce el riesgo esperado. Revisar diseño y configuración relacionados con comprobar reconciliación de balances, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden comprobar reconciliación de balances. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-IRR-009	AP3	Evaluar reservas y liquidez de crisis	Determinar, mediante evidencia verificable y validación no destructiva, si evaluar reservas y liquidez de crisis reduce el riesgo esperado. Revisar diseño y configuración relacionados con evaluar reservas y liquidez de crisis, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden evaluar reservas y liquidez de crisis. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-IRR-010	AP3	Revisar comunicación a clientes y reguladores	Determinar, mediante evidencia verificable y validación no destructiva, si revisar comunicación a clientes y reguladores reduce el riesgo esperado. Revisar diseño y configuración relacionados con revisar comunicación a clientes y reguladores, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden revisar comunicación a clientes y reguladores. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-IRR-011	AP4	Ejecutar ejercicio integral de crisis	Determinar, mediante evidencia verificable y validación no destructiva, si ejecutar ejercicio integral de crisis reduce el riesgo esperado. Revisar diseño y configuración relacionados con ejecutar ejercicio integral de crisis, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden ejecutar ejercicio integral de crisis. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.
CSPTF-TEST-IRR-012	AP4	Validar remediación y lecciones aprendidas	Determinar, mediante evidencia verificable y validación no destructiva, si validar remediación y lecciones aprendidas reduce el riesgo esperado. Revisar diseño y configuración relacionados con validar remediación y lecciones aprendidas, contrastarlos con invariantes y requisitos, y validar su eficacia mediante consultas de solo lectura, datos sintéticos, simulación o reproducción segura.	PASS: Existe diseño aprobado, la implementación coincide con el diseño, la evidencia demuestra eficacia y no se identifican rutas razonables que invaliden validar remediación y lecciones aprendidas. FAIL: Falta de control, evidencia insuficiente, configuración inconsistente, bypass reproducible en entorno autorizado o dependencia no tratada.

Amenazas y debilidades

Threat ID	Escenario de amenaza	Weakness ID	Patrón de debilidad
CSPTF-THRT-IRR-001	Contención tardía de drenaje	CSPTF-WEAK-IRR-001	Playbooks genéricos
CSPTF-THRT-IRR-002	Pérdida de evidencia forense	CSPTF-WEAK-IRR-002	Pausas no ensayadas
CSPTF-THRT-IRR-003	Recuperación con claves comprometidas	CSPTF-WEAK-IRR-003	Dependencia de personas únicas
CSPTF-THRT-IRR-004	Descuadre de reservas tras incidente	CSPTF-WEAK-IRR-004	Reconciliación manual lenta
CSPTF-THRT-IRR-005	Comunicación errónea que amplifica impacto	CSPTF-WEAK-IRR-005	Backups y claves de recuperación no validados

Gate de cierre del dominio

- Aplicabilidad y exclusiones justificadas.
- Controles seleccionados con evidencia proporcional al perfil.
- Tests clasificados pass, fail, inconclusive o formally not-tested.
- Findings con owner, plazo, disclosure handling y retest.
- Dependencias críticas y riesgo residual visibles para el decision maker.

Anexo A - Crosswalk por dominio

Dominio	MITRE AADAPT	NIST CSF 2.0	Alineación OWASP	EEA EthTrust
GOV	Reconnaissance; Resource Development; Initial Access; Impact; Fraud	GV; ID	SCSTG engagement planning; SCSVS governance context	Limited
ARC	Execution; Privilege Escalation; Defense Evasion; Impact; Fraud	GV; ID; PR	SCSTG architecture and threat modeling; SCSVS architecture	Primary
CRY	Credential Access; Execution; Defense Evasion; Impact; Fraud	PR	SCSTG cryptography; SCSVS cryptography	Primary
KEY	Credential Access; Collection; Defense Evasion; Impact; Fraud	PR; DE; RS	SCSTG authentication and authorization; SCSVS access control	Primary
SCT	Execution; Privilege Escalation; Defense Evasion; Impact; Fraud	ID; PR; DE	SCSTG test catalog; SCSVS requirements; SCWE weaknesses	Primary
DAP	Initial Access; Execution; Credential Access; Collection; Fraud	PR; DE	SCSTG dApp and client interaction; SCSVS communications	Primary
TOK	Execution; Privilege Escalation; Impact; Fraud	PR; DE	SCSTG token interactions; SCSVS business logic	Primary
DEF	Execution; Impact; Fraud	ID; PR; DE	SCSTG DeFi and economic testing; SCSVS business logic	Primary
ORA	Execution; Defense Evasion; Impact; Fraud	PR; DE; RS	SCSTG oracle security; SCSVS oracle controls	Primary
BRG	Initial Access; Execution; Credential Access; Impact; Fraud	ID; PR; DE; RS	SCSTG cross-contract and cross-chain interactions	Primary
NET	Resource Development; Initial Access; Execution; Lateral Movement; Impact	PR; DE; RC	OWASP scope is partial; CSPTF extension	Limited
L2	Execution; Privilege Escalation; Defense Evasion; Impact; Fraud	ID; PR; DE; RC	OWASP scope is partial; CSPTF extension	Limited
CEX	Initial Access; Credential Access; Lateral Movement; Collection; Impact; Fraud	GV; PR; DE; RS; RC	OWASP scope is partial; CSPTF extension	Limited
API	Reconnaissance; Initial Access; Execution; Credential Access; Collection; Impact	PR; DE	OWASP API Security Top 10; SCSTG RPC interactions	Supporting
INF	Initial Access; Execution; Privilege Escalation; Credential Access; Lateral Movement; Impact	PR; DE; RC	OWASP DevSecOps and supply-chain practices	Supporting
IAM	Initial Access; Privilege Escalation; Credential Access; Lateral Movement; Collection; Fraud	GV; PR; DE	OWASP ASVS authentication and access control	Supporting
SUP	Resource Development; Initial Access; Execution; Defense Evasion; Impact	GV; ID; PR	OWASP Software Component Verification Standard themes	Supporting
REG	Collection; Defense Evasion; Impact; Fraud	GV; ID; PR	OWASP privacy and data protection themes	Limited
MON	Defense Evasion; Collection; Impact; Fraud	DE; RS	SCSTG logging and event verification	Supporting

Dominio	MITRE AADAPT	NIST CSF 2.0	Alineación OWASP	EEA EthTrust
IRR	Defense Evasion; Impact; Fraud	RS; RC	SCSTG incident-aware testing; CSPTF extension	Supporting

Anexo B - Investigación y validación

Metodología de investigación

La revisión estructurada utiliza fuentes primarias: estándares, knowledge bases, especificaciones, papers, propuestas de protocolo y regulación. La inclusión exige relevancia directa, autoría identificable, estabilidad y capacidad de mapearse a arquitectura, amenaza, control, prueba, evidencia, riesgo o gobernanza. Se excluyen fuentes anónimas, marketing sin sustento, duplicados secundarios y contenido no verificable.

La síntesis codifica cada fuente por capa del sistema, propiedad de seguridad, evidencia, adversary behavior y método. Es una revisión narrativa estructurada, no una systematic literature review registrada.

Brecha identificada

La revisión no identificó una fuente pública única que combine whole-system scope, autorización especializada, controles y tests, alineación adversaria, riesgo cripto-económico, evidencia, reporte y retest en custodia, contracts, DeFi, bridges, nodes, L2, CEX, API, cloud, insider, monitoring y recovery.

La inferencia está limitada a fuentes revisadas y fecha; no niega marcos privados o posteriores.

Plan de validación

- 30. content validity con paneles expertos;
- 31. revisión independiente de mappings;
- 32. retrospective y prospective case studies;
- 33. inter-rater reliability;
- 34. calibración del scoring;
- 35. usability y efficiency.

Antes de v1.0 se requiere comentario público, revisión de dominios críticos, casos documentados, identificadores estables y revisión legal/safety.

Anexo C - Registro de fuentes

ID	Año	Autor/organización	Fuente	Relevancia
REF-001	2025	MITRE	MITRE AADAPT: Adversarial Actions in Digital Asset Payment Technologies	Tácticas y técnicas adversarias para sistemas de gestión de activos digitales.
REF-002	2025	MITRE	MITRE Introduces AADAPT Cybersecurity Framework for Cryptocurrency	Contexto, alcance y lanzamiento oficial de AADAPT.
REF-003	2026	OWASP Foundation	OWASP Smart Contract Security Testing Guide (SCSTG)	Metodología y casos de prueba para contratos inteligentes.
REF-004	2026	OWASP Foundation	OWASP Smart Contract Security Verification Standard (SCSVS)	Requisitos verificables para smart contracts, dApps y protocolos EVM.

ID	Año	Autor/organización	Fuente	Relevancia
REF-005	2026	OWASP Foundation	OWASP Smart Contract Weakness Enumeration (SCWE)	Enumeración de debilidades de contratos inteligentes.
REF-006	2025	Enterprise Ethereum Alliance	EEA EthTrust Security Levels Specification Version 3	Requisitos de revisión y certificación de contratos Solidity.
REF-007	2008	Scarfone, Souppaya, Cody, Orebaugh	NIST SP 800-115: Technical Guide to Information Security Testing and Assessment	Planificación, ejecución, análisis y mitigación en evaluaciones técnicas.
REF-008	2024	NIST	Cybersecurity Framework 2.0	Gobernanza y ciclo de gestión del riesgo cibernético.
REF-009	2018	Yaga, Mell, Roby, Scarfone	NISTIR 8202: Blockchain Technology Overview	Fundamentos, componentes y riesgos de blockchain.
REF-010	2023	NIST	FIPS 186-5: Digital Signature Standard	Requisitos para algoritmos de firma digital.
REF-011	2022	NIST	SP 800-218: Secure Software Development Framework (SSDF)	Desarrollo seguro y cadena de suministro de software.
REF-012	2026	MITRE	MITRE ATT&CK	Comportamiento adversario complementario a AADAPT.
REF-013	2026	MITRE	MITRE D3FEND	Contramedidas y técnicas defensivas.
REF-014	2026	OWASP Foundation	OWASP Web Security Testing Guide	Patrón de organización de pruebas de seguridad web.
REF-015	2017	Atzei, Bartoletti, Cimoli	A Survey of Attacks on Ethereum Smart Contracts (SoK)	Taxonomía seminal de ataques a contratos Ethereum.
REF-016	2016	Luu, Chu, Olickel, Saxena, Hobor	Making Smart Contracts Smarter	Análisis simbólico y vulnerabilidades de smart contracts.
REF-017	2018	Tsankov et al.	Securify: Practical Security Analysis of Smart Contracts	Análisis semántico y patrones de cumplimiento/violación.
REF-018	2018	Nikolic et al.	Finding The Greedy, Prodigal, and Suicidal Contracts at Scale	Análisis a escala de comportamientos vulnerables.
REF-019	2020	Durieux, Ferreira, Abreu, Cruz	Empirical Review of Automated Analysis Tools on 47,587 Ethereum Smart Contracts	Limitaciones, falsos positivos y complementariedad de herramientas.
REF-020	2020	Daian et al.	Flash Boys 2.0: Frontrunning in Decentralized Exchanges, Miner Extractable Value, and Consensus Instability	MEV, ordenamiento y efectos económicos/consenso.
REF-021	2021	Qin et al.	Attacking the DeFi Ecosystem with Flash Loans for Fun and Profit	Ataques económicos con liquidez temporal.
REF-022	2021	Su et al.	Evil Under the Sun: Understanding and Discovering Attacks on Ethereum Decentralized Applications	Medición y patrones de ataques reales contra dApps.
REF-023	2021	So, Hong, Oh	SmarTest: Effectively Hunting Vulnerable Transaction Sequences in Smart Contracts	Secuencias transaccionales y ejecución simbólica guiada.

ID	Año	Autor/organización	Fuente	Relevancia
REF-024	2021	He et al.	EOSAFE: Security Analysis of EOSIO Smart Contracts	Seguridad de contratos fuera del EVM.
REF-025	2024	Liao et al.	SmartAxe: Detecting Cross-Chain Vulnerabilities in Bridge Smart Contracts via Fine-Grained Static Analysis	Vulnerabilidades y semántica cross-chain.
REF-026	2024	Augusto et al.	XChainWatcher: Monitoring and Identifying Attacks in Cross-Chain Bridges	Monitoreo y detección de ataques de bridges.
REF-027	2024	Wu et al.	Safeguarding Blockchain Ecosystem: Understanding and Detecting Attack Transactions on Cross-chain Bridges	Incidentes, patrones y detección de ataques cross-chain.
REF-028	2024	OASIS	STIX Version 2.1	Intercambio estructurado de inteligencia de amenazas.
REF-029	2023	FIRST	Common Vulnerability Scoring System Version 4.0	Referencia de severidad técnica; CSPTF añade dimensiones económicas y sistémicas.
REF-030	2026	OpenSSF	Supply-chain Levels for Software Artifacts (SLSA)	Procedencia e integridad de artefactos.
REF-031	2026	OWASP Foundation	CycloneDX Specification	SBOM y transparencia de componentes.
REF-032	2021	FATF	Updated Guidance for a Risk-Based Approach to Virtual Assets and VASPs	AML/CFT y obligaciones de VASP.
REF-033	2023	European Union	Regulation (EU) 2023/1114 on Markets in Crypto-assets (MiCA)	Requisitos regulatorios para criptoactivos y proveedores.
REF-034	2022	European Union	Regulation (EU) 2022/2554 on digital operational resilience for the financial sector (DORA)	Resiliencia operacional y pruebas en entidades financieras.
REF-035	2026	Bitcoin Improvement Proposals	BIP-32: Hierarchical Deterministic Wallets	Derivación jerárquica de claves.
REF-036	2026	Bitcoin Improvement Proposals	BIP-39: Mnemonic code for generating deterministic keys	Frases mnemónicas y generación de seeds.
REF-037	2026	Ethereum Improvement Proposals	EIP-712: Typed structured data hashing and signing	Firmas estructuradas y presentación de intención.
REF-038	2026	Ethereum Improvement Proposals	ERC-1967: Proxy Storage Slots	Almacenamiento y proxies actualizables.
REF-039	2008	Satoshi Nakamoto	Bitcoin: A Peer-to-Peer Electronic Cash System	Modelo base de consenso y pagos digitales.
REF-040	2026	Gavin Wood et al.	Ethereum Yellow Paper	Semántica formal del EVM y protocolo Ethereum.

Anexo D - Inventario y limitaciones

Objeto	Cantidad
Dominios	20
Controles	160
Tests	240
Amenazas	100
Debilidades	100
Perfiles	4
Niveles de evidencia	6

Limitaciones: contenido normativo Spanish-first; mappings temáticos; risk weights no calibrados; no certification scheme; revisión narrativa estructurada; anexos específicos por cadena pendientes.

Los records machine-readable y archivos Markdown individuales forman parte de la release. El PDF es una vista de publicación; JSON/CSV son la fuente de automatización.